

INFRA SECURITY PROJECT

모의해킹 기반 정보보호 진단

또롱이 공공자전거 통합운영 서비스 결과보고서

팀명

4 팀 사뿐히뚫조

팀원

김보미, 김정훈, 유성우,
홍기수



목차

공공자전거 통합운영 서비스를 직접 구축하고, 모의해킹을 통해 주요 보안 위협을 재현하였습니다. 이후 보안솔루션과 통합 로그 분석을 통해 공격 탐지·대응 및 개선 결과를 도출하였습니다.

01

프로젝트 개요

가상기업 소개와 프로젝트 추진 배경, 목표 및 수행 범위

02

서비스 및 인프라 구축

공공자전거 서비스와 서버·네트워크·보안 인프라 구성

03

취약점 진단 및 영향 분석

주요 취약점 재현·원인 분석·보완·재검증 및 탐지 대응

04

악성코드 분석

정적·동적 분석을 통한 악성 행위 및 데이터 변조 확인

05

부록 | 추가 자료 및 증거

본문 보완 자료·추가 검증 결과·운영 증거 정리

06

프로젝트 결과 및 개선방안

수행 결과·보안 효과·프로젝트 회고·향후 개선사항

01

PROJECT OVERVIEW

프로젝트 개요와 수행 계획 및 범위

또롱이 공공자전거 통합운영 서비스의 추진 배경과 목표를 정의하고,
팀별 역할 · 수행 일정 · 프로젝트 범위를 기반으로 전체 수행 방향을 제시합니다.

01

프로젝트 개요

서비스 목표 및 추진 배경 정의

02

팀원별 수행 업무

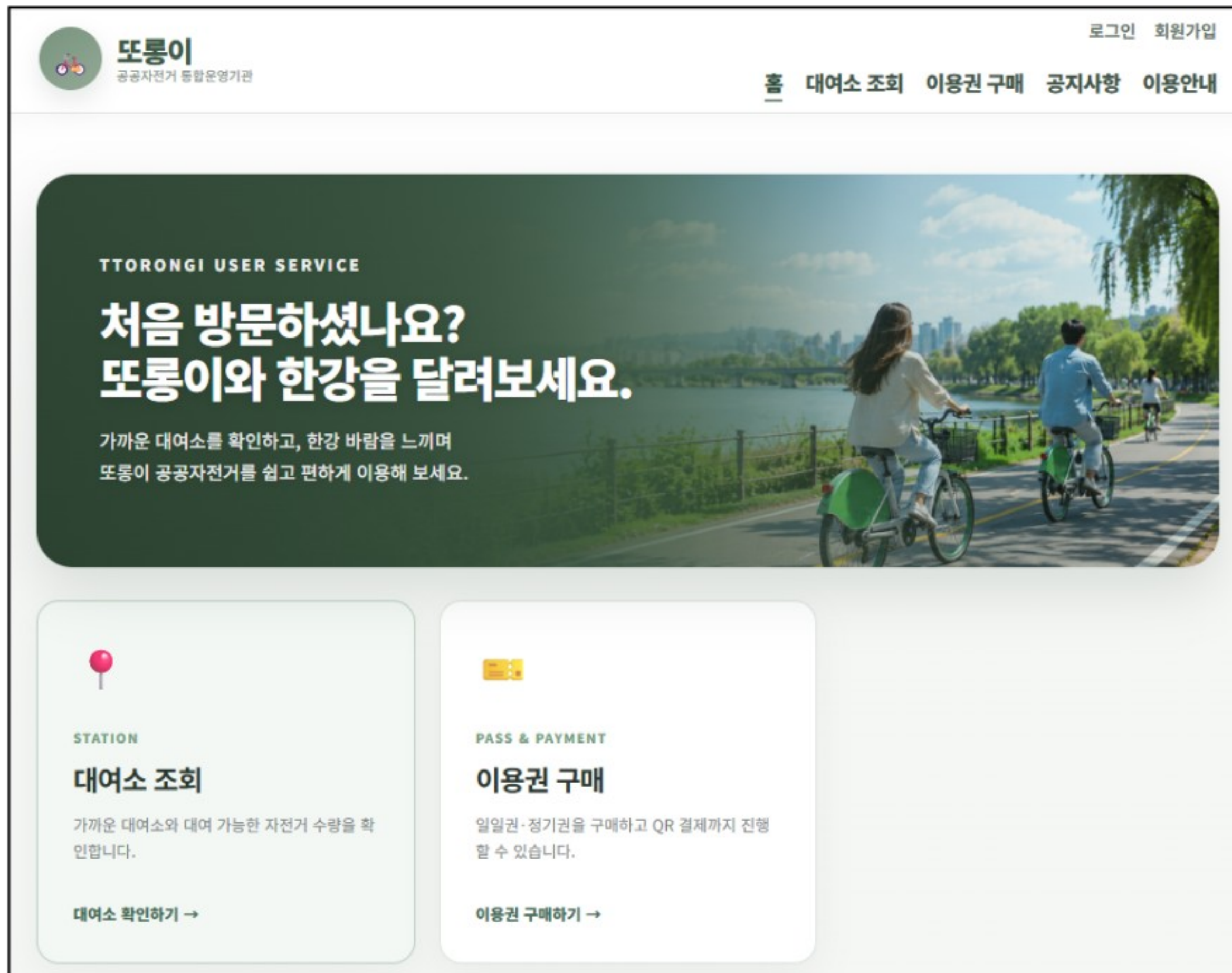
역할 분담 및 담당 영역 구성

03

수행 일정 및 범위

단계별 프로젝트 일정 수립 및 구축 · 진단 · 탐지 · 개선 범위 정의

01. 프로젝트 개요



- **프로젝트명** 또롱이 공공자전거 통합운영 서비스
- **목표** 공공자전거 서비스의 보안 위협 재현 및 다중 보안체계의 탐지·차단 효과 검증
- **핵심 기술** pfSense, WAF, Snort IDS/IPS, Wazuh SIEM, OpenVPN, Flask·MariaDB 기반 서비스
- **프로젝트 선정 배경**
 - 시민 생활과 밀접한 공공서비스
 - 다양한 사용자·운영 주체 존재
 - 웹·DB·네트워크 보안 실습 가능
 - 통합 로그 수집 및 탐지 검증에 적합

01. 팀원별 수행 업무



김보미 (팀장)

프로젝트 총괄 및
시스템 통합

- 프로젝트 PM 및 일정 · 품질 관리
- 웹 서버 구축 및 서비스 환경 구성
- 웹 · DB · 네트워크 · 보안 시스템
전체 연동
- pfSense 정책 조정 및
Wazuh 로그 연동
- 보고서 작성 및 최종 산출물 통합



김정훈

증적 수집 및
자료 정리

- 서비스 및 인프라 화면 캡처
- 공격 · 탐지 결과 화면 정리
- 수행 단계별 이미지 분류



유성우

서비스 점검 및
공격 시나리오 수행

- 웹 서비스 및 보안 설정 전반 점검
- 공격 시나리오 설계 · 작성 · 실행
- Wazuh 탐지 룰 추가 및
각 서버별 로그 수집 연동
- 취약점 분석 및 모의해킹 내용 정리
- 악성코드 제작



홍기수

보안 솔루션 구축 및
악성코드 분석

- 방화벽 · IDS/IPS · SIEM 구축
- 보안솔루션 탐지 · 차단 룰 설정
- 규칙별 이벤트 및 로그 검증
- FLARE 분석용 악성코드 수정
- 악성코드 정적 · 동적 분석 및
결과 정리

01. 프로젝트 일정

서비스와 인프라를 구축한 뒤, 취약점 진단·보안 보완·재검증을 순차적으로 수행했습니다.
이후 악성코드 분석과 보안솔루션 탐지 결과를 통합해 최종 결과를 도출했습니다.

항목	7/23	7/24	7/25	7/27	7/30	8/5	일정
기획·구조 설계							서비스 범위 및 서버·네트워크 구조 설계
서비스·인프라 구축							WEB·DB·LOG 서버와 역할별 서비스 구축
취약점 진단·보완							모의해킹 수행, 원인 분석, 보안 통제 적용
악성코드·탐지 분석							정적·동적 분석 및 Snort·Wazuh 탐지 검증
결과 통합·발표							재검증 결과 정리, 보고서 제출 및 발표

01. 프로젝트 수행 범위

서비스 구축

웹·DB·DNS 기반
공공자전거 서비스 구성

취약점 진단

인증·접근통제·QR·
업무 로직·설정 오류 점검

보안 탐지

WAF·Snort·Wazuh 기반
공격 로그 수집 및 경보 생성

보안 적용 및 재검증

보안 적용 후 동일 공격
재수행 및 효과 비교

통합 보안체계 구축 및 검증

구축·진단·탐지·재검증

02

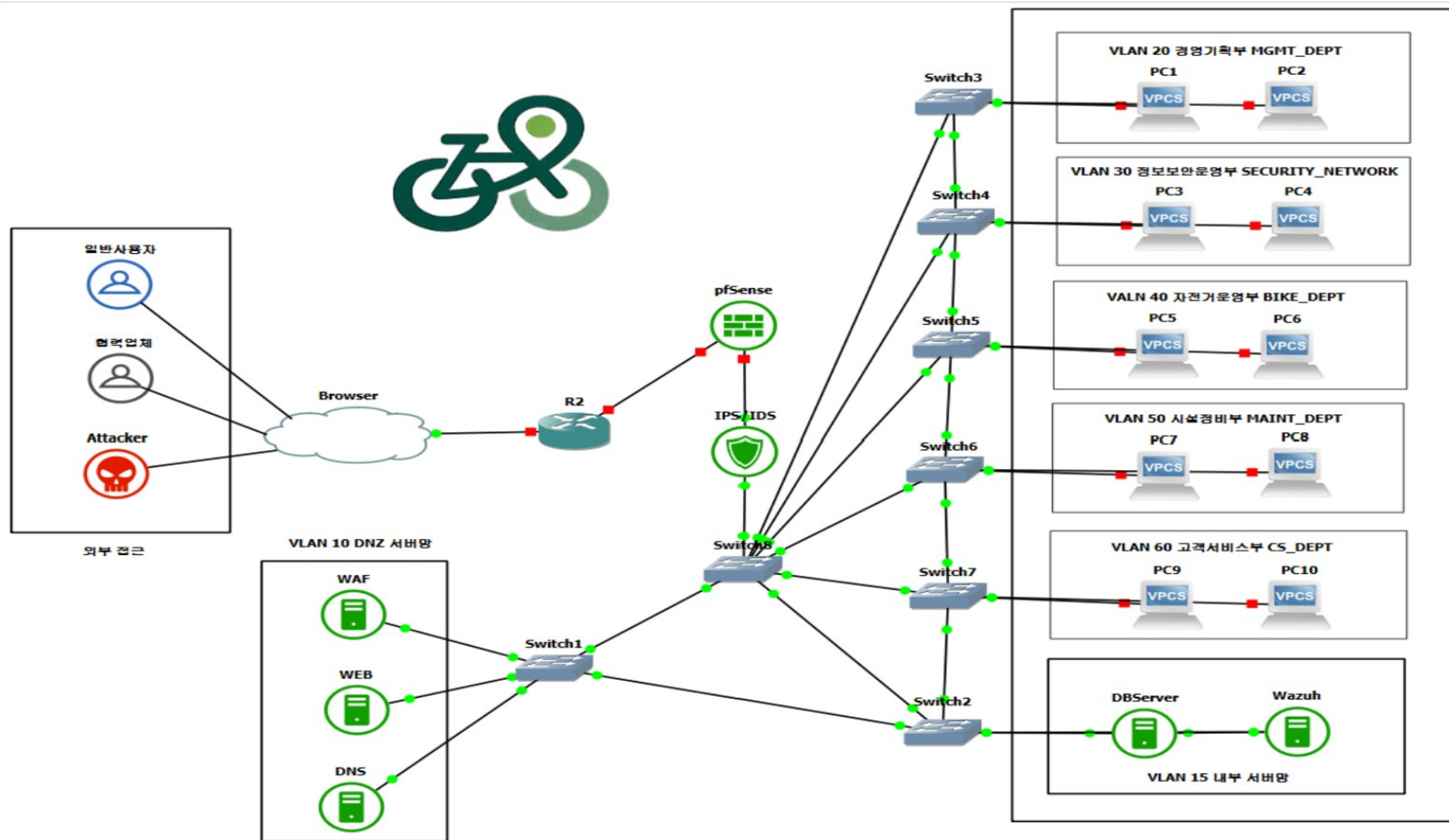
SERVICE &
INFRASTRUCTURE

서비스 및 인프라 구축과 통합 보안 환경 구성

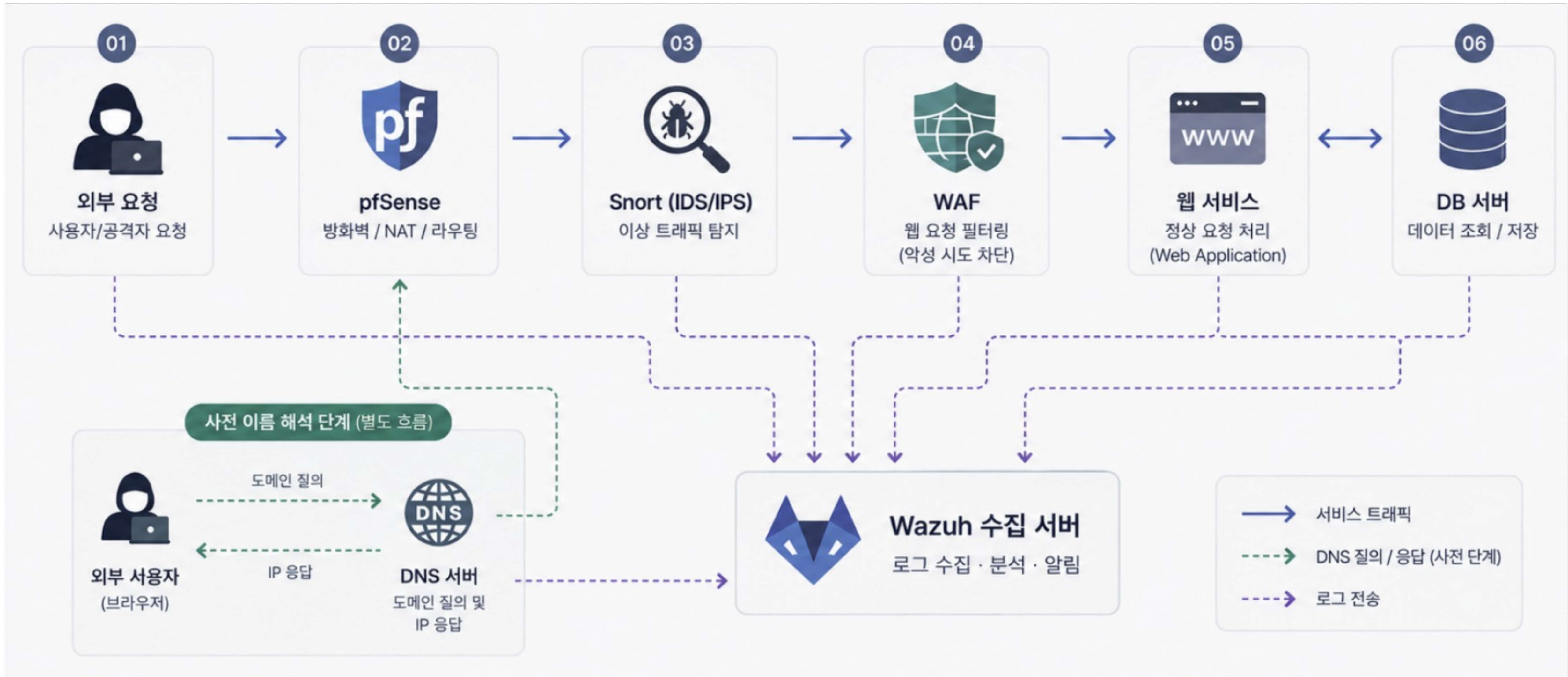
공공자전거 서비스 운영을 위한 네트워크·서버 환경을 구축하고,
사용자별 서비스와 통합 로그 수집·보안 솔루션을 연계합니다.



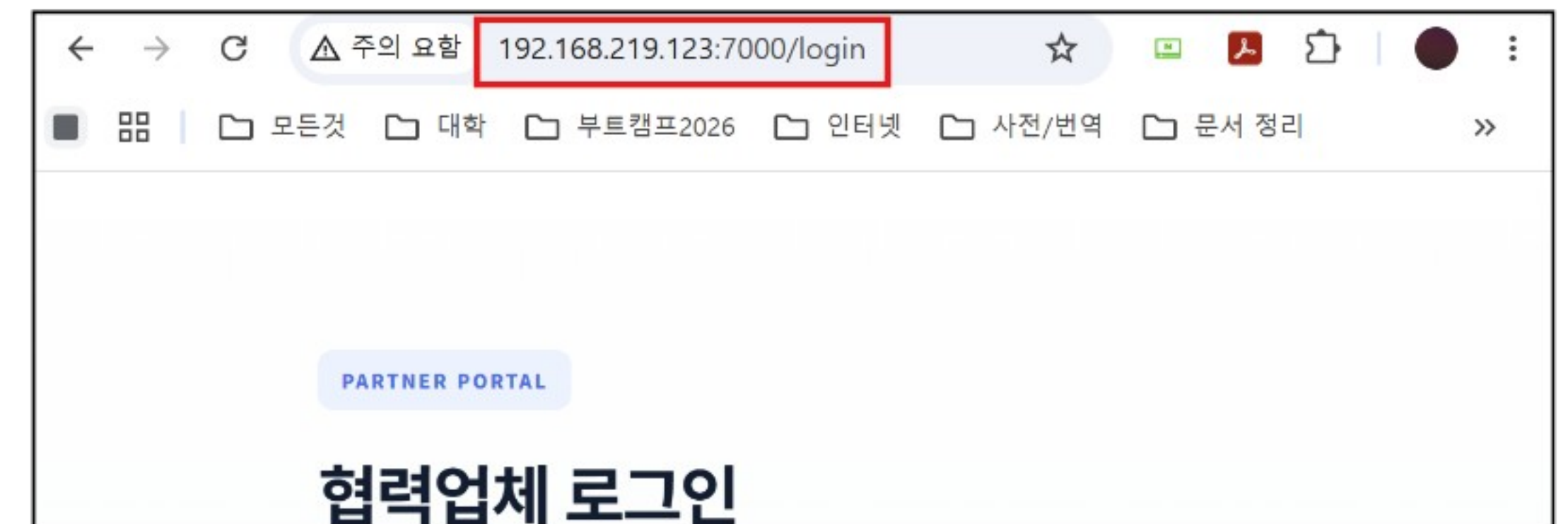
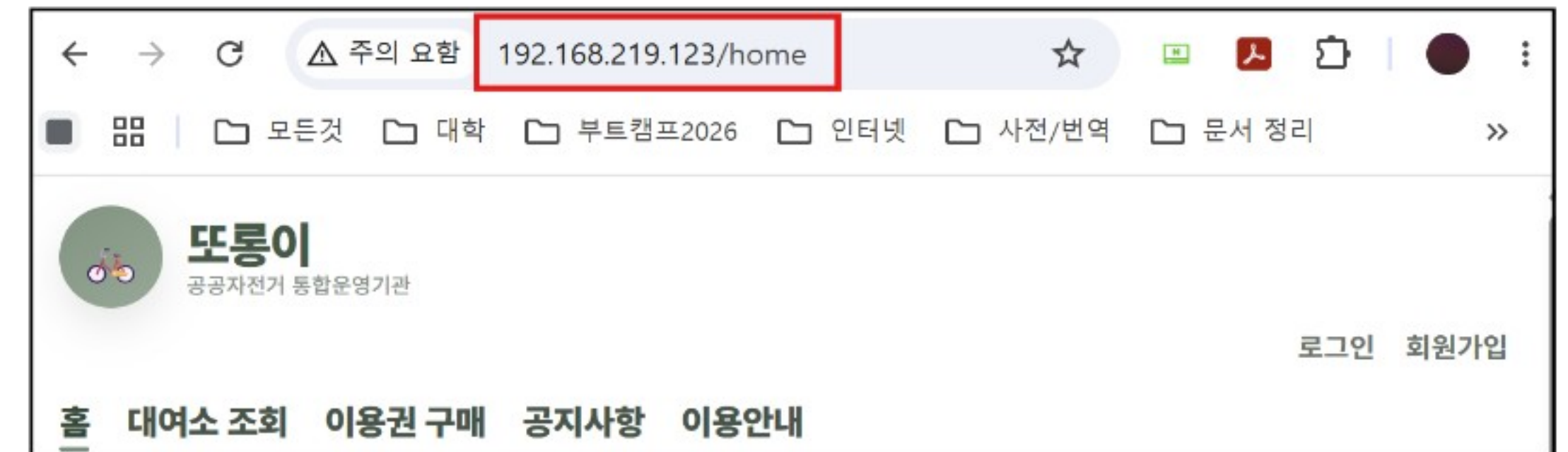
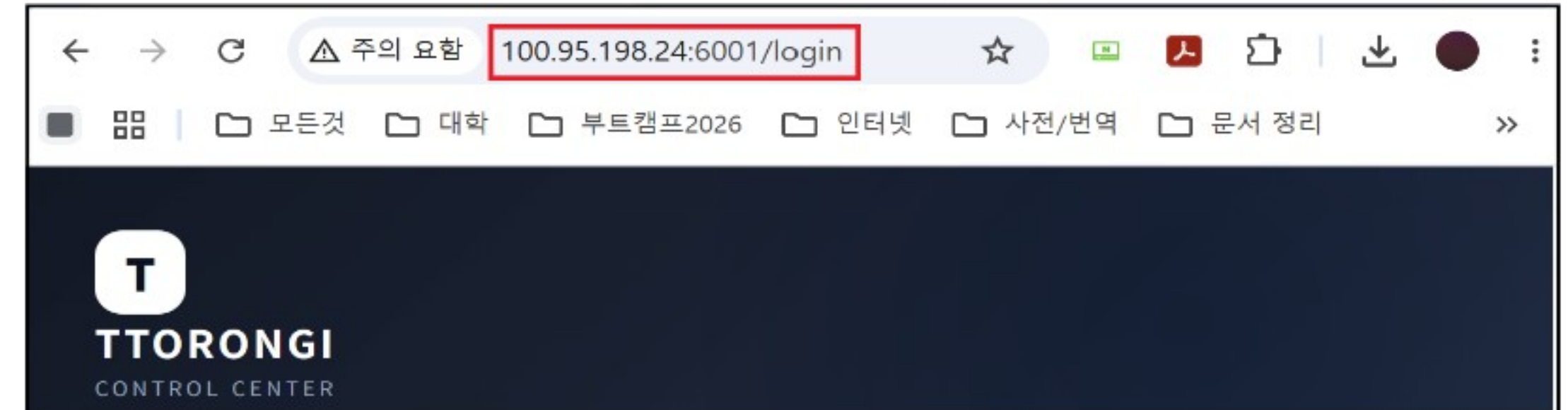
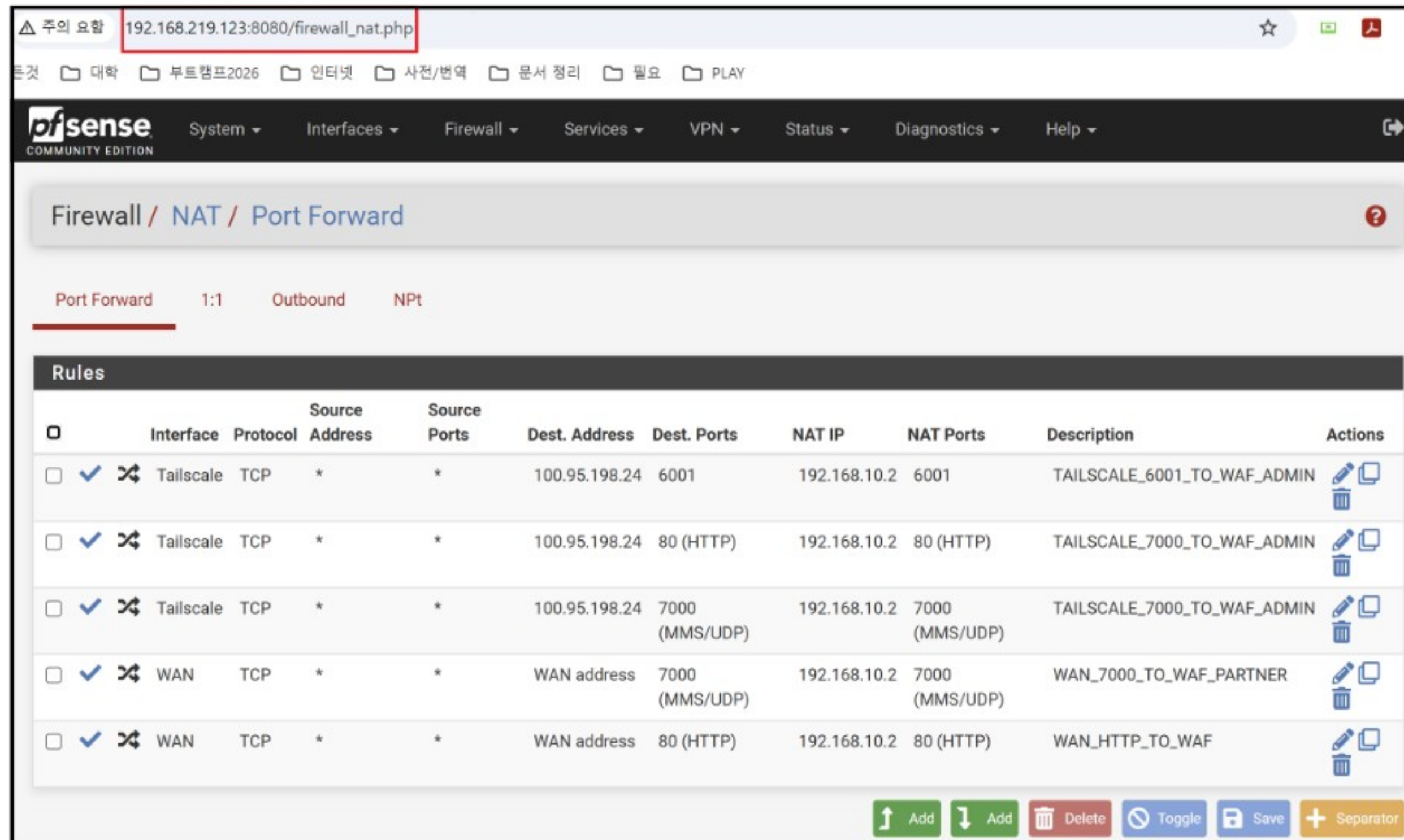
02. 기관 전체 인프라 구성도



02. 논리 네트워크 구성도 + 통신 흐름도



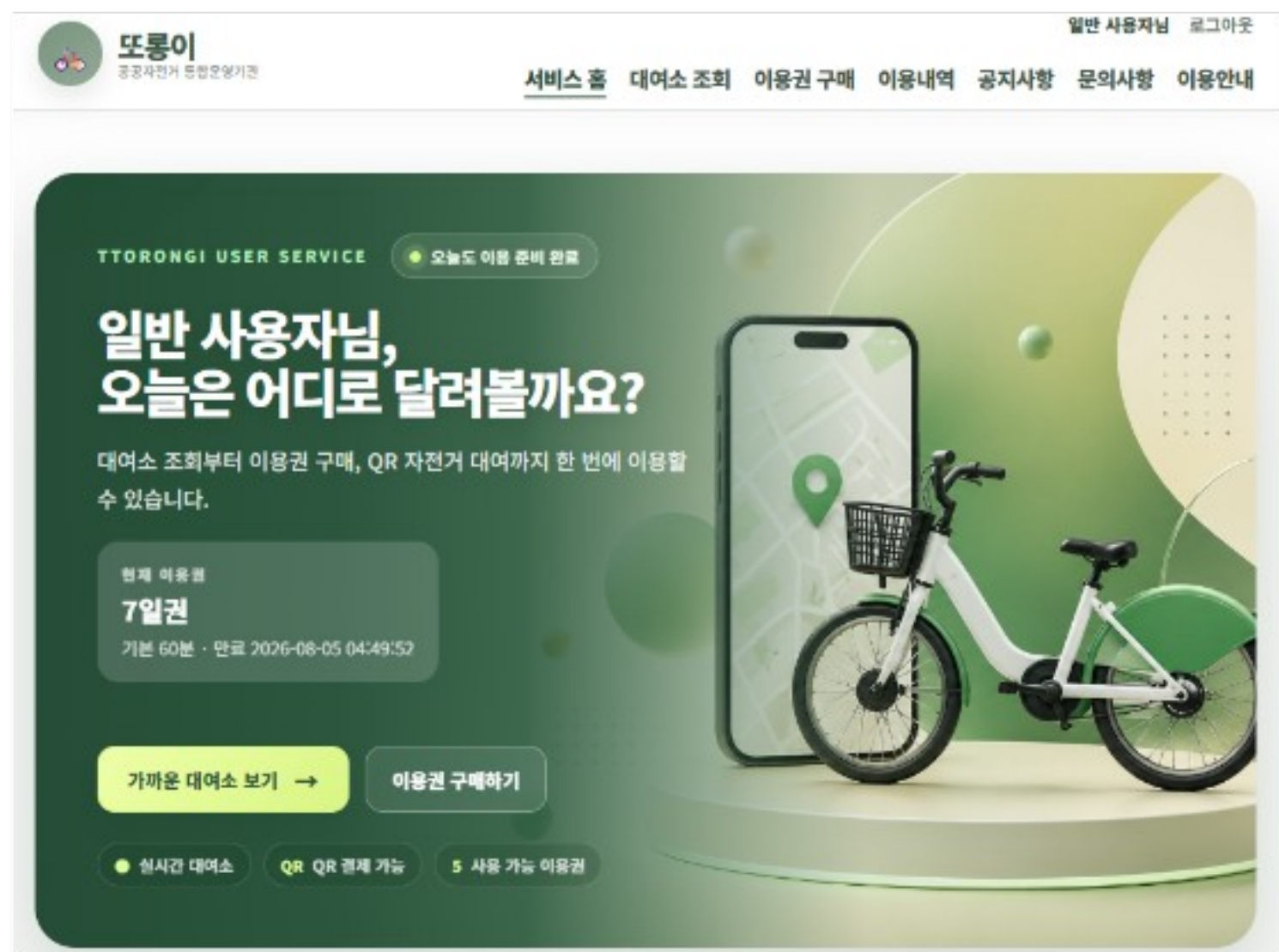
02. 외부 접근 경로 및 서비스 분리



외부 요청을 pfSense 경유로 제한하고
서비스별 목적지 포트를 분리

02. 또롱이 서비스 구성

포트 5000

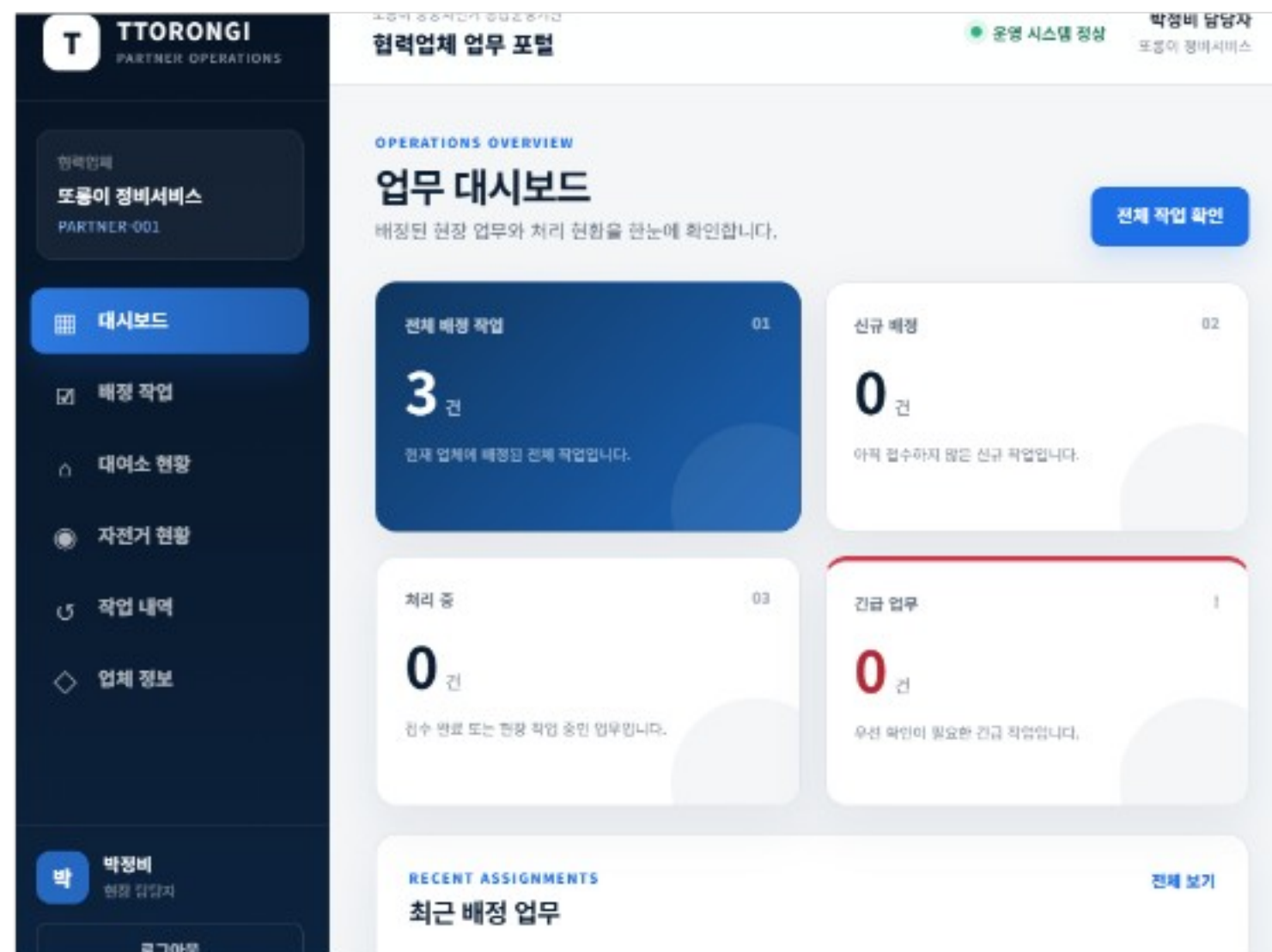


웹 서버 내부 포트

사용자 서비스

- 일반 이용자를 위한 공공자전거 서비스 기능 제공

포트 7000

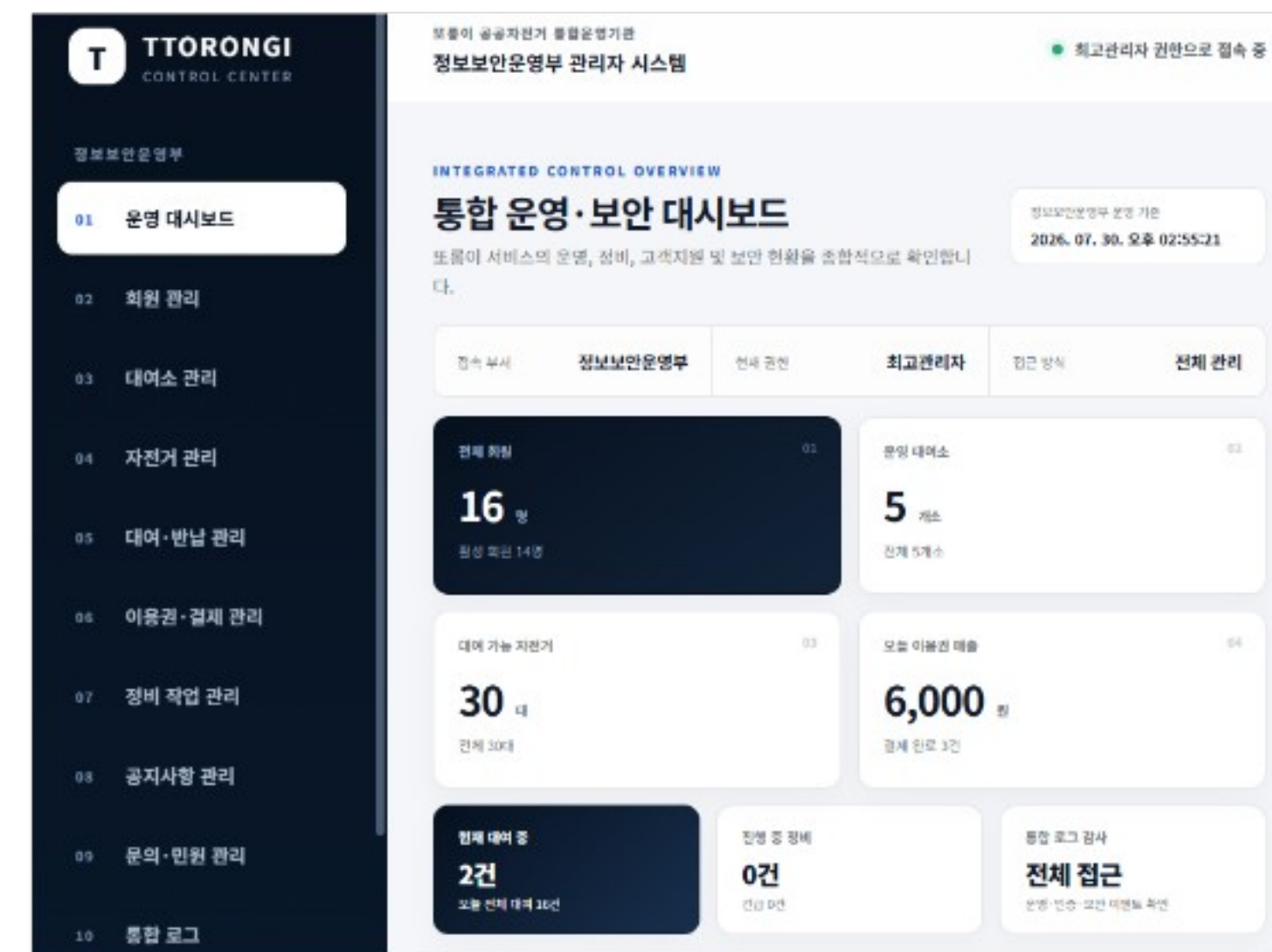


웹 서버 내부 포트

협력업체 서비스

- 협력업체의 현장 운영과 유지보수 업무 지원

포트 6001



웹 서버 내부 포트

관리자 서비스

- 전반적인 웹서비스 관리

02. 사용자 서비스 - QR 기반 대여



[시나리오 2 연계] QR 토큰 변조 공격 분석 대상 지점

[시나리오 3 연계] 동일 자전거 중복 대여 (RACE) 공격 대상 지점

02. 사용자 서비스 - 대여 · 반납 처리 흐름



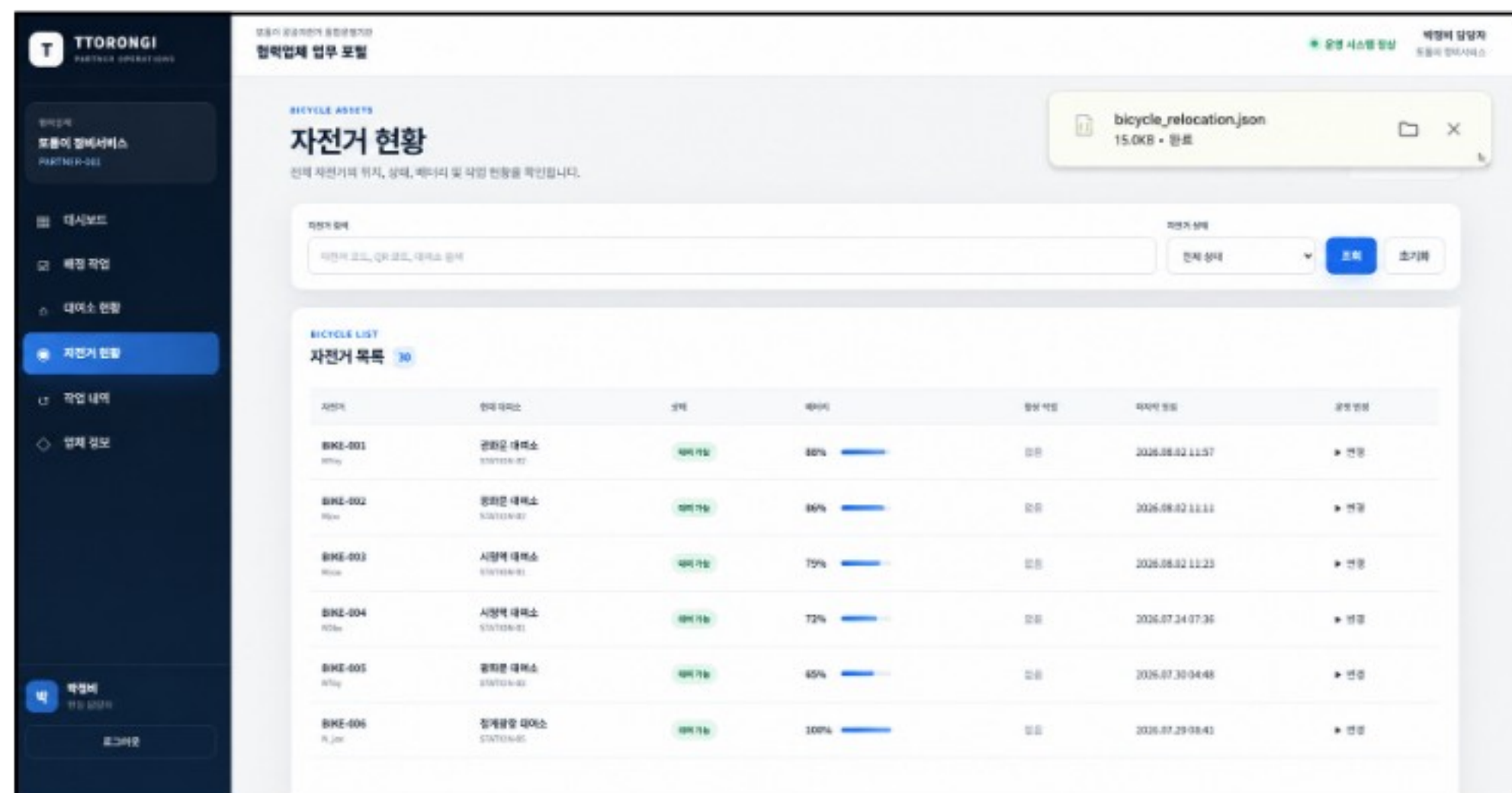
[시나리오 1 연계] 타 사용자 대여정보 조회 및 강제 반납 공격 대상 지점

02. 협력업체 서비스 - 운영자료 내보내기 흐름

01

협력업체 전용 데이터 추출

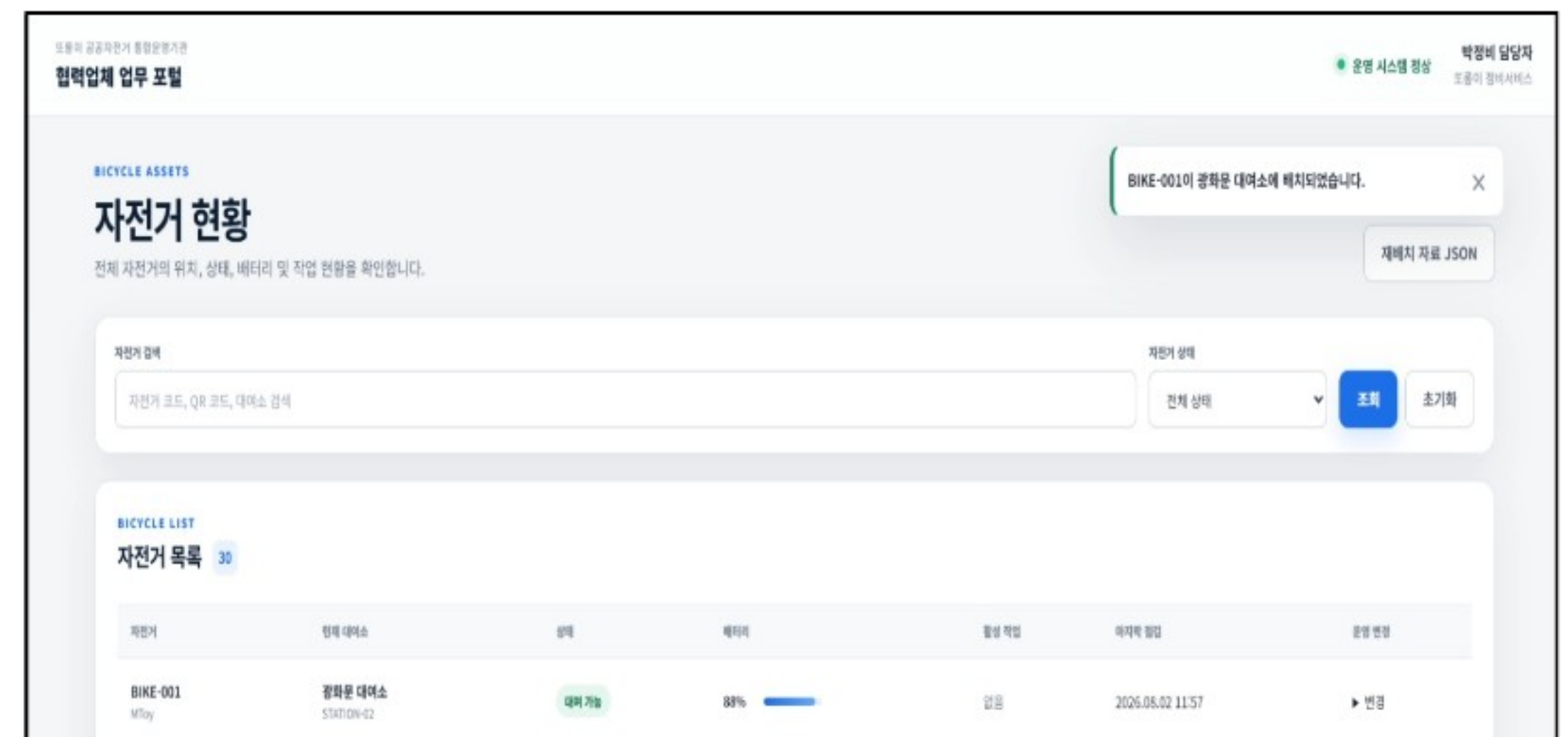
- 정산 및 운영 자료 조회
- 내보내기 (다운로드) 기능



02

자전거 상태 정보 수정

- 고장, 정비 등 상태값 변경
- 관리자 / 협력업체 권한 처리



[보호 대상 데이터 정의] 중요 운영정보가 악성코드에 의해 변조될 수 있으므로 무결성 보호 필요

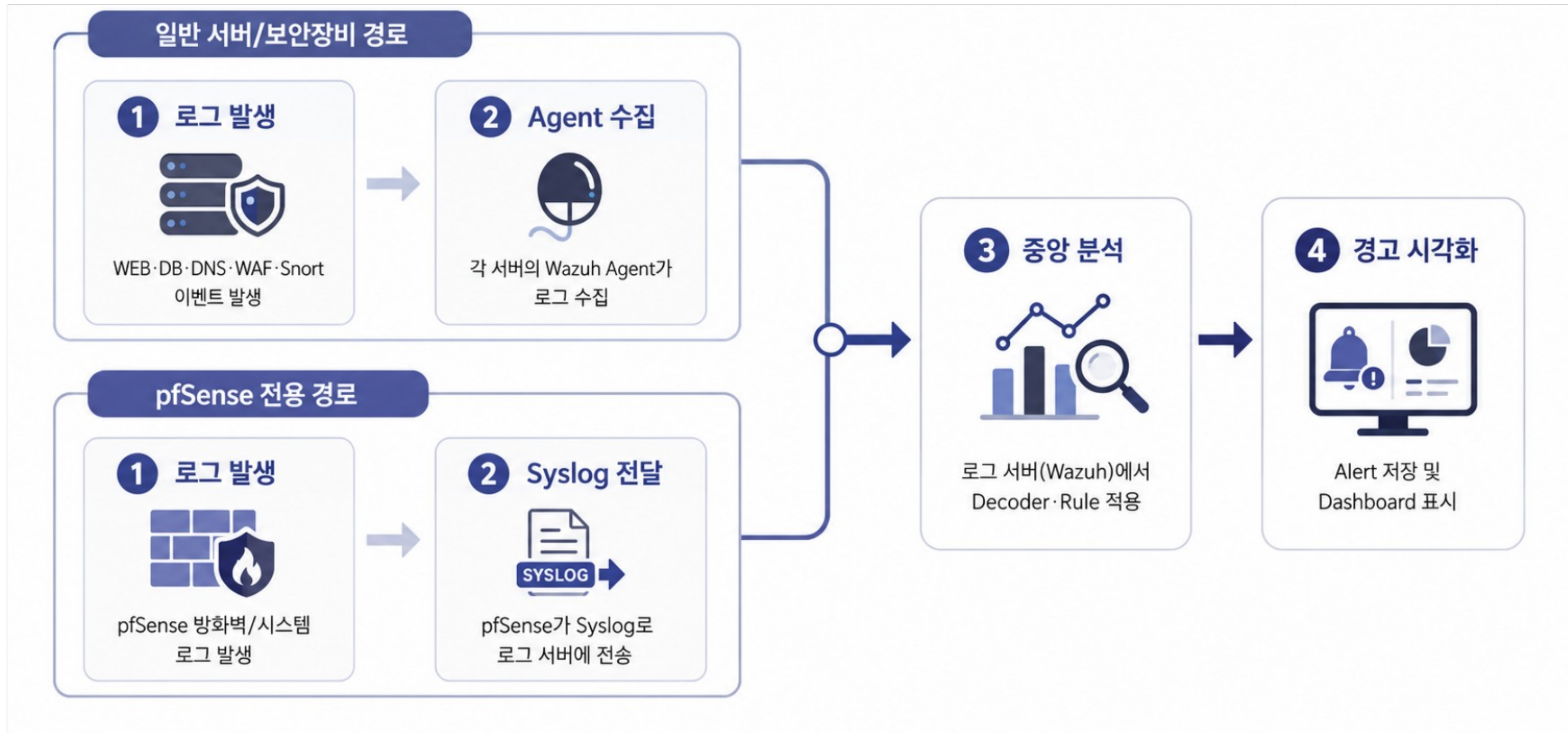
시나리오 4 연계 | 운영자료 비인증 다운로드 공격 대상 지점

시나리오 5 연계 | 자전거 상태 변경 감사로그 미기록 대상 지점

02. 보안 솔루션 구성



02. Wazuh 기반 통합 로그 수집 구조



03

SECURITY
ASSESSMENT

취약점 진단과 영향 분석

시나리오별 공격을 재현하고 발생 원인과 영향을 분석한 뒤,
보안 통제 적용 전후 결과를 비교합니다.

01

취약점 진단

시나리오 기반 취약점 식별 및 발생 원인 확인

02

로그 · 영향 분석

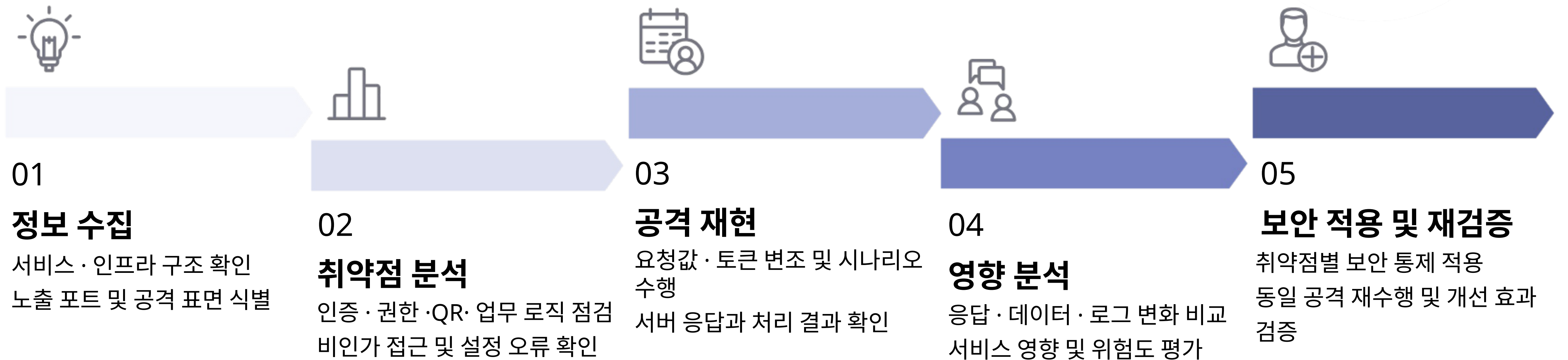
공격 행위의 로그 기록과 서비스 · 데이터 영향 분석

03

보안 개선 검증

보안 통제 적용 후 차단 및 감사로그 생성 여부 확인

03. 모의해킹 수행 절차



검증 기준

공격 요청부터 서버 응답, 데이터 변화, 보안 로그까지 단계별 증거를 수집하여 개선 효과를 검증했습니다.

03. 모의해킹 시나리오 전체 요약

주요 모의해킹 시나리오 요약

2026.08.04 기준

번호	OWASP 분류 코드	시나리오	위험도
1	A01	타 사용자 대여정보 조회 · 강제 반납	심각
2	A02	예측 가능한 QR 토큰 변조	높음
3	A04	동일 자전거 동시 중복 대여	심각
4	A05	운영자료 비인증 다운로드	높음
5	A09	운영정보 변경 및 감사정보 부족	높음

진단 결과

총 5 개 시나리오에서 심각 · 높음 수준의 취약점을 확인하고,
보안 통제 적용 후 동일 공격을 재수행하여 개선 효과를 검증했습니다.

03. 시나리오 1.1 - 타 사용자 대여정보 조회 · 강제 반납

또롱이
공공자전거 통합운영기관

서비스 홈 대여소 조회 이용권 구매 이용내역 공지사항 문의사항 이용안내

USER01님 로그아웃

대여 중

이용내역 RENTAL DETAIL

대여 상세

자전거 이용정보와 반납 상태를 확인하세요.

자전거 번호
BIKE-007
QR Nook

배터리
99%

사용 이용권
7일권
PASS-7D

대여번호
#46

이용자
USER01

출발 대여소
시청역 대여소
STATION-01

반납 대여소
반납 대기

대여 시작
2026-07-30 08:29:51

반납 시작
-

이용시간
이용 중

초과 이용요금
0원

RETURN BICYCLE

자전거 반납

반납할 대여소를 선택해 주세요.

반납 대여소 선택

자전거 반납

1. 취약 진단

대여 식별자를 변경하여 타 사용자
대여정보 조회 및 강제 반납 가능 여부
확인

Request

Pretty Raw Hex

```

1 GET /rental/detail?rental_id=46 HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://localhost:3000/
9 Cookie: session=.eJyrVspLzE1VslIKDXNMjBS0lEqys8B8UuLU4uAPBAVn5miZGVoZArhQdWdMED1tQCGUxP4.amsNOg.CG_kBNYWZgaOk00fISJFALPFiPI
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12

```

2. 원인 및 영향 분석

서버 측 소유권 검증 미흡으로
타 사용자 정보 조회 · 반납 가능

03. 시나리오 1.2 - 보안 이벤트 탐지 및 로그 분석

```
{
  "timestamp": "Mon Aug 03 00:38:12.895980 2026",
  "client_ip": "192.168.10.1",
  "rule_id": "300024",
  "message": "[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected",
  "severity": "CRITICAL",
  "hostname": "100.95.198.24",
  "request_uri": "/rental/return-by-id",
  "referer": "http://100.95.198.24/rental/detail?rental_id=69"
}

{
  "timestamp": "Mon Aug 03 00:47:02.677872 2026",
  "client_ip": "192.168.10.1",
  "rule_id": "300024",
  "message": "[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected",
  "severity": "CRITICAL",
  "hostname": "100.95.198.24",
  "request_uri": "/rental/return-by-id",
  "referer": "http://100.95.198.24/history"
}
```

Aug 3, 2026 @ 15:11:51.133	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
Aug 3, 2026 @ 15:11:51.121	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
Aug 3, 2026 @ 14:36:10.152	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
Aug 3, 2026 @ 14:36:10.143	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
Aug 3, 2026 @ 13:56:27.059	ttorongi-web	[A01] 타 사용자의 대여 상세정보가 비인가 사용자에게 노출됨	13	110104
Aug 3, 2026 @ 13:30:32.353	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023

3. 탐지 이벤트 확인

타 사용자 대여정보 조회 · 강제 반납
요청이 Wazuh 보안 이벤트로
탐지됨

wazuh-alerts-4.x-2026.08.03	
005	
100.104.251.116	  
ttorongi-waf	
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1] ModSecurity: Warning. Pattern match "^([0-9]+)\$" at ARGS:rental_id. [file "/etc/modsecurity/blueteam.conf"] [line "105"] [id "300024"] [msg "[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected"] [severity "CRITICAL"] [tag "TTORONGI-01"] [tag "OWASP-A01"] [tag "IDOR"] [hostname "100.95.198.24"] [uri "/rental/return-by-id"] [unique id "am	
1785717493.118226	
log	
/var/log/apache2/modsec_audit.log	
logserver	
[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 요청 탐지	
4	
ttorongi, waf, scenario01, owasp_a01, ttorongi_attack, A01, idor, waf, return_request	
120024	
11	
false	
Aug 3, 2026 @ 09:38:13.145	

001	
100.77.91.115	
ttorongi-web	
security	
rental_detail_owner_mismatch	
GET	
scenario01_collection_test_1785732970	
99902	
99999	
/rental/detail	
success	
ttorongi-user	
warning	
127.0.0.1	
true	
Aug 3, 2026 @ 13:56:25.388	
99901	
scenario01-test	
json	
/var/log/ttorongi/application.json	
logserver	
[A01] 타 사용자의 대여 상세정보가 비인가 사용자에게 노출됨	
ttorongi, ttorongi, ttorongi_attack, A01, idor, attack_success, d	
110104	
13	
Aug 3, 2026 @ 13:56:27.059	

4. 로그 상세 분석

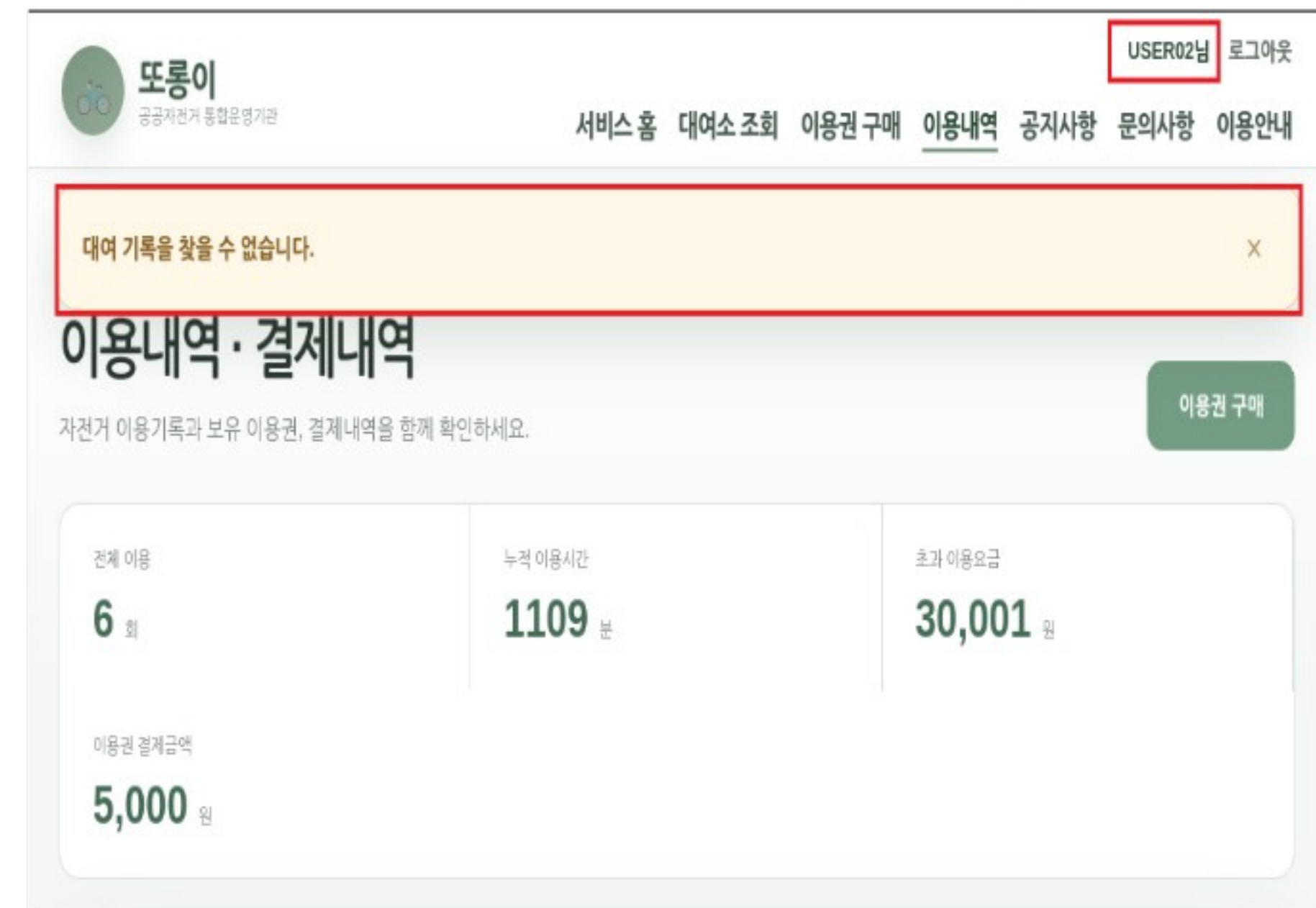
조회 요청과 강제 반납 요청을 구분하여
위험도와 탐지 규칙을 각각 적용

03. 시나리오 1.3 - 보안 조치 적용 및 재검증



5. 보안 조치 적용

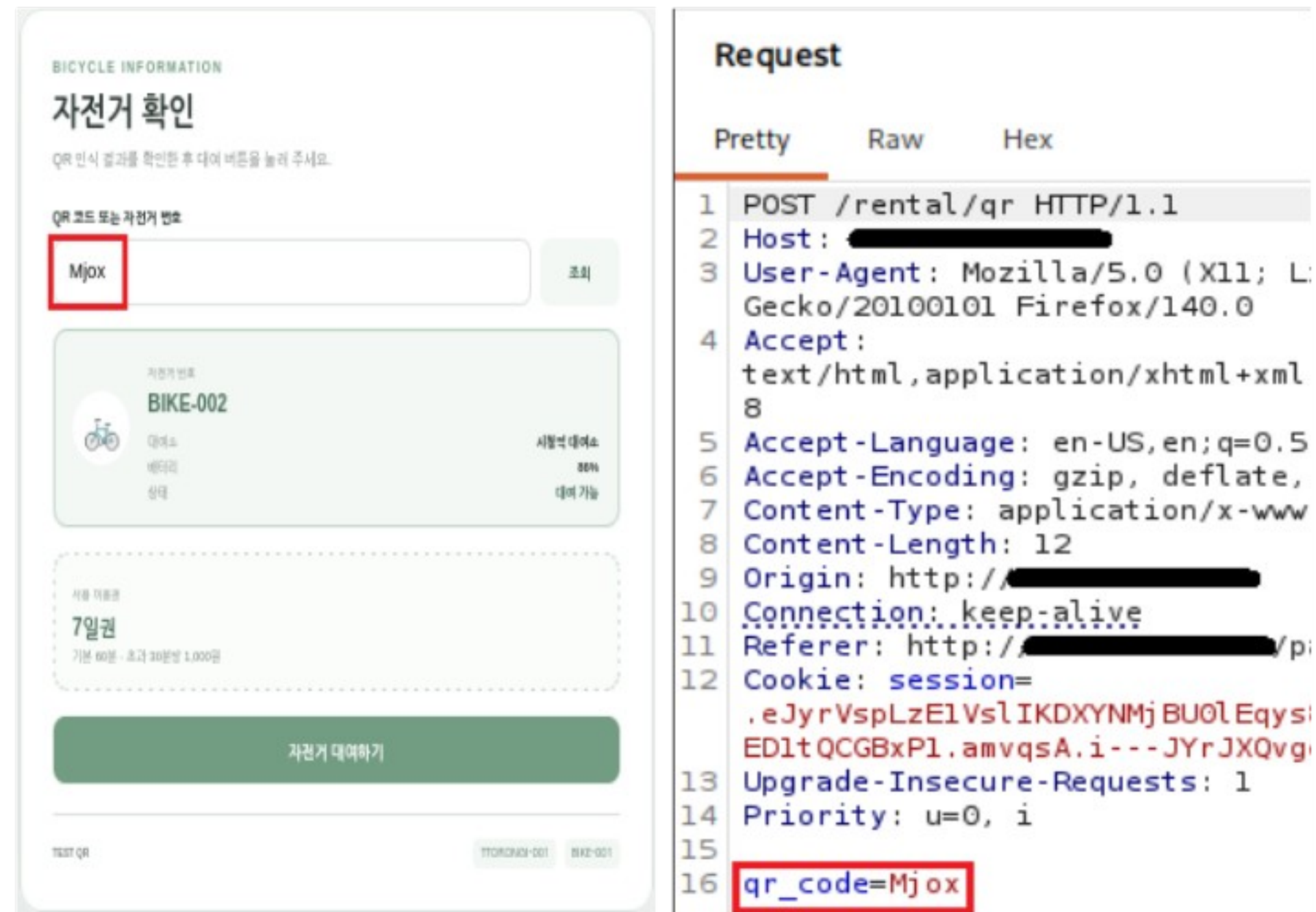
서버 측 소유권 · 권한 검증을 적용하여
타 사용자 자원 접근 차단



6. 동일 요청 재검증

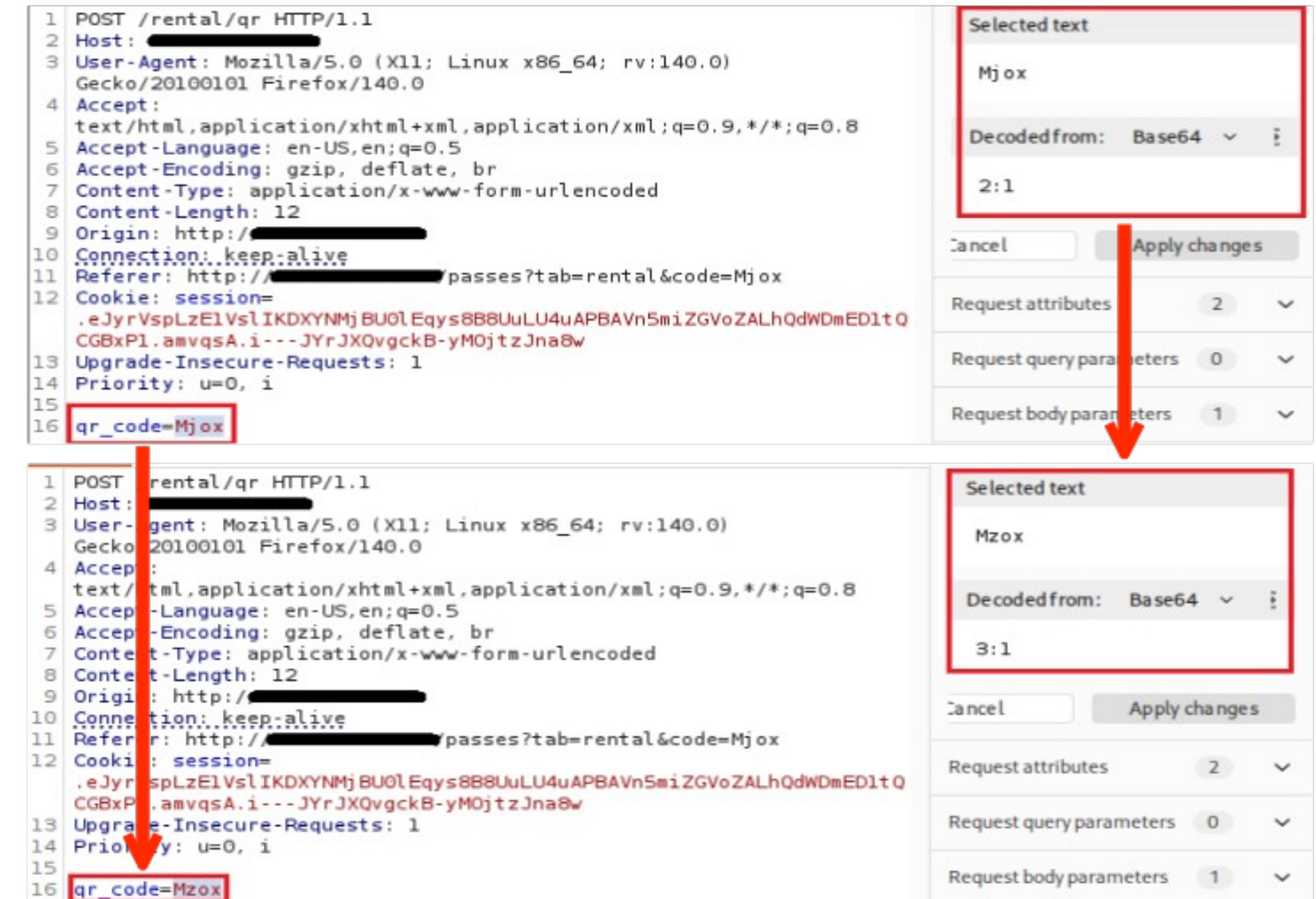
동일한 식별자 변조 요청을 재수행하여
타 사용자 조회 · 반납 차단 확인

03. 시나리오 2.1 - QR 토큰 변조 및 비정상 대여



1. 취약 진단

QR 토큰 구조를 분석하여
자전거 · 대여소 식별자 변조 가능 여부
확인



2. 원인 및 영향 분석

예측 가능한 식별자 기반 QR 토큰을
변조하여 임의 자전거 대여 가능

03. 시나리오 2.2 - 보안 이벤트 탐지 및 로그 분석

```

"timestamp": "2026-08-03T01:47:57.071+0000",
"rule": {
  "level": 8,
  "description": "[TTORONGI-02][A02][Flask] 비정상 QR 토큰 제출 이벤트 탐지 : 사용자 142, IP 192.168.10.1, 경로 /rental/qr",
  "id": "120025",
  "firedtimes": 3,
  "mail": false,
  "groups": [
    "ttorongi",
    "scenario02",
    "owasp_a02",
    "qr_token",
    "ttorongi_attack",
    "A02",
    "flask",
    "qr_token",
    "invalid token",
    "attack_detected"
  ]
},
"agent": {

```

Aug 3, 2026 @ 13:41:47.717	ttorongi-web	PAM: Login session closed.	3	5502
Aug 3, 2026 @ 13:41:47.674	ttorongi-web	Successful sudo to ROOT executed.	3	5402
Aug 3, 2026 @ 13:41:29.121	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 13:41:29.119	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 13:41:25.117	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 13:41:25.117	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029

3. 탐지 이벤트 확인

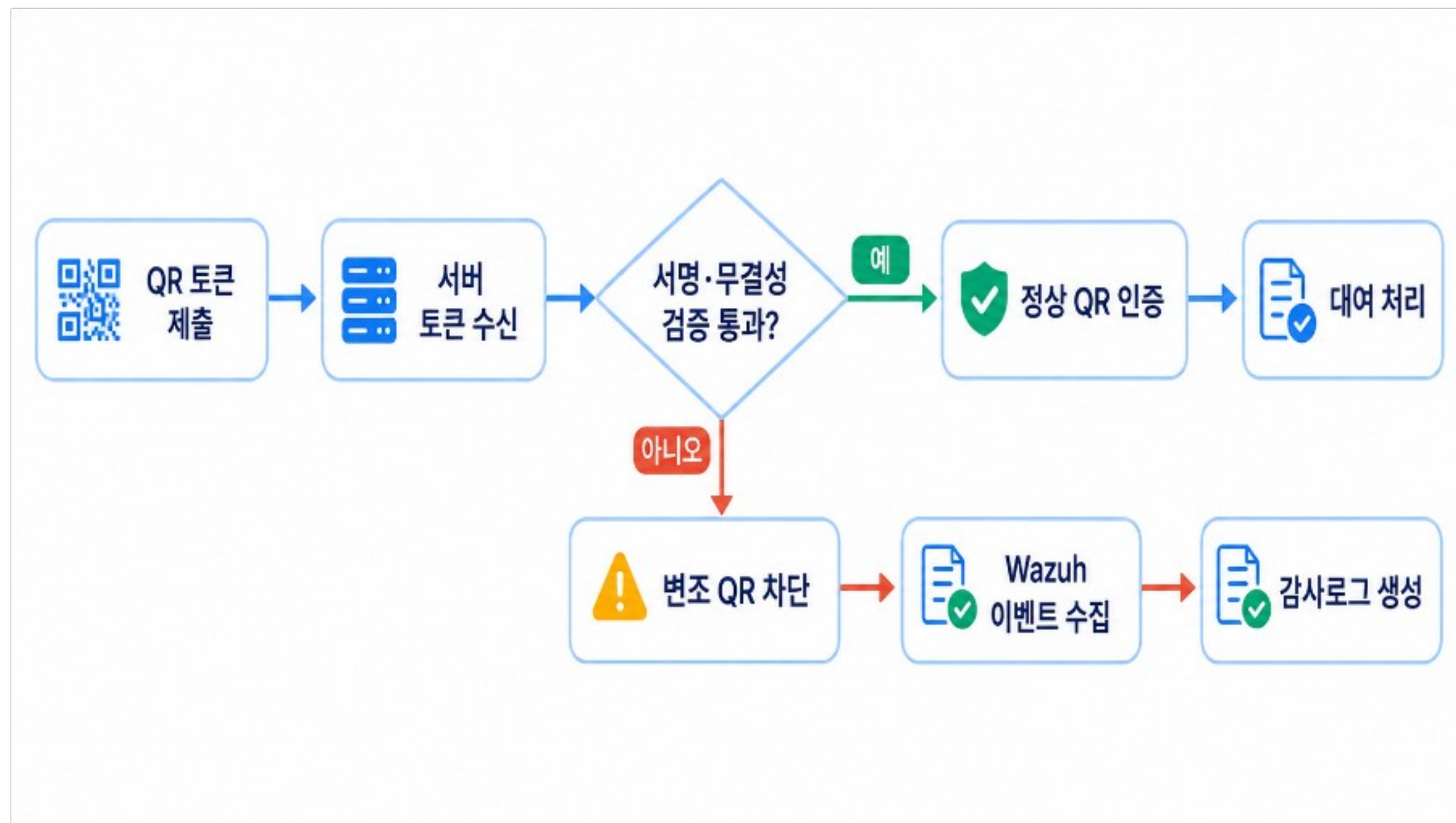
QR 토큰 변조 · 재사용 요청이
Wazuh 보안 이벤트로 탐지됨

_index	wazuh-alerts-4.x-2026.08.03
agent.id	004
agent.ip	100.109.154.86
agent.name	ttorongi-snort
decoder.name	ttorongi-snort
full_log	08/03-04:41:28.542078 [**] [1:1000031:6] "[TTORONGI-02][A02][Snort] QR Rental Request Traffic Detected" [**] [Priority: 0] {TCP} 192.168.10.2:36820 -> 192.168.10.10:5000
id	1785732089.2936605
input.type	log
location	/var/log/snort-inline/alert_fast.txt
manager.name	logserver
predecoder.timestamp	08/03-04:41:28.542078
rule.description	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지
rule.firedtimes	14
rule.groups	ttorongi, scenario02, owasp_a02, qr_token, ttorongi_attack, A02, snort, ips, qr_token, token_tampering, attack_blocked
rule.id	120029
rule.level	11
rule.mail	false
timestamp	Aug 3, 2026 @ 13:41:29.121

4. 로그 상세 분석

변조 · 재사용 유형을 구분하고
사용자 · 자전거 · 실패 원인을 상세
기록

03. 시나리오 2.3 - 보안 조치 적용 및 재검증



5. 보안 조치 적용

난수 기반 일회성 토큰과 상태 검증을
적용하여 QR 토큰의 변조·재사용 차단

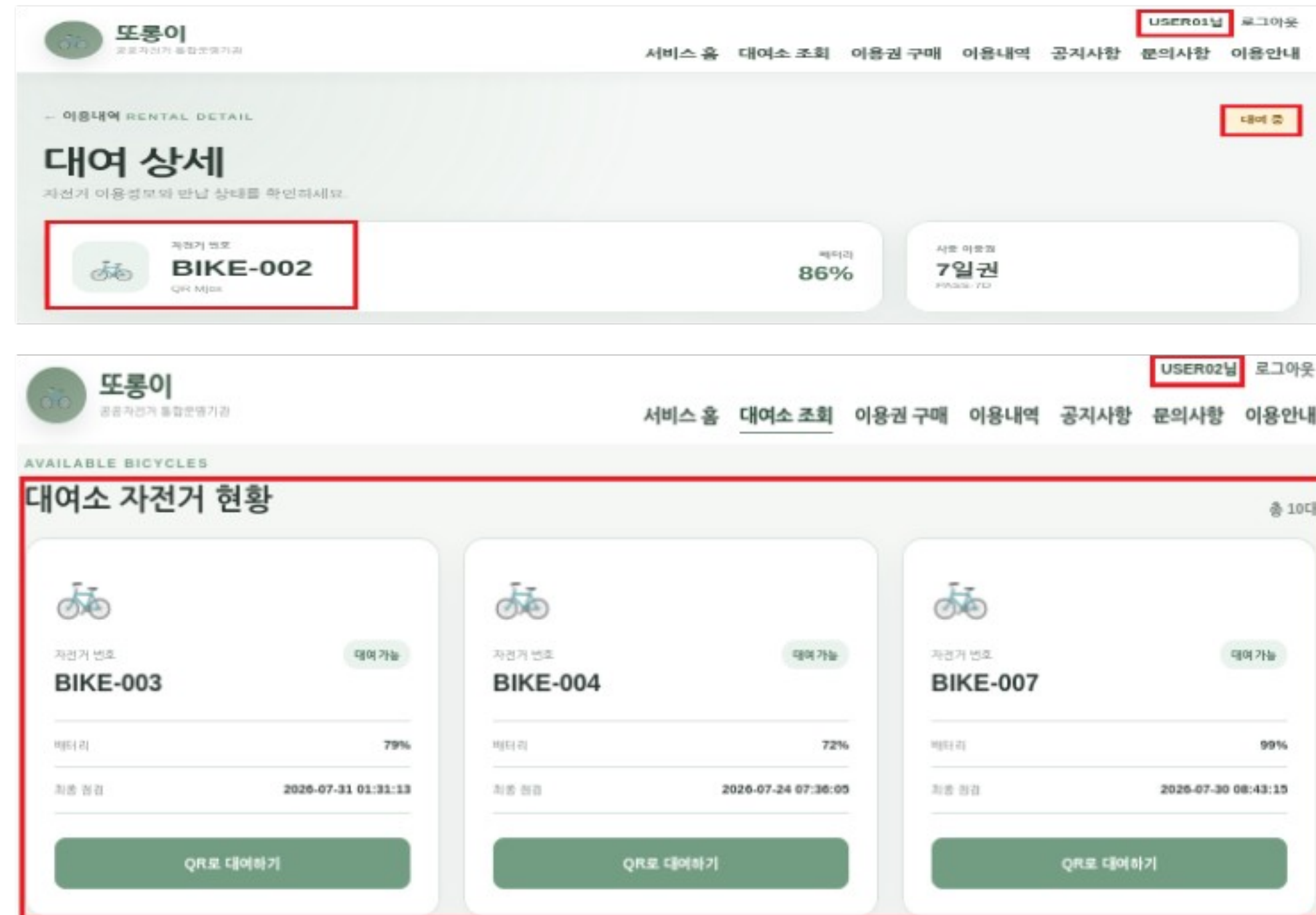
_index	wazuh-alerts-4.x-2026.08.03	_index	wazuh-alerts-4.x-2026.08.03
agent.id	001	agent.id	001
agent.ip	100.77.91.115	agent.ip	100.77.91.115
agent.name	ttorongi-web	agent.name	ttorongi-web
data.bicycle_id	18	data.bicycle_id	MTg6MTpmZThQLVZRvNz6OFJjckVEMjZyTURVaFVoYWRmYT
data.category	security	data.category	security
data.event_type	qr_station_mismatch	data.event_type	invalid_qr_attempt
data.http_method	POST	data.http_method	POST
data.message	QR 대여소 정보와 자전거의 현재 위치 불일치	data.message	등록되지 않은 QR 코드 대여 시도
data.request_path	/rental/qr	data.request_path	/rental/qr
data.result	failure	data.result	failure
data.service	ttorongi-user	data.service	ttorongi-user
data.severity	warning	data.severity	warning
data.source_ip	192.168.10.1	data.source_ip	192.168.10.1
data.timestamp	Aug 3, 2026 @ 13:42:10.813	data.timestamp	Aug 3, 2026 @ 13:42:10.814
data.user_id	125	data.user_id	125
decoder.name	json	decoder.name	json

Aug 3, 2026 @ 13:42:11.020	ttorongi-web	또동이 잘못된 QR 대여 시도: 자전거 MTg6MTpmZThQLVZR...	8	110600
Aug 3, 2026 @ 13:42:10.976	ttorongi-web	[TTORONGI-02][A02][Flask] 변조된 QR 대여소 정보 탐지: ...	9	120026
Aug 3, 2026 @ 13:41:47.717	ttorongi-web	PAM: Login session opened.	3	5501
Aug 3, 2026 @ 13:41:47.717	ttorongi-web	PAM: Login session closed.	3	5502
Aug 3, 2026 @ 13:41:47.674	ttorongi-web	Successful sudo to ROOT executed.	3	5402
Aug 3, 2026 @ 13:41:29.121	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029

6. 동일 요청 재검증

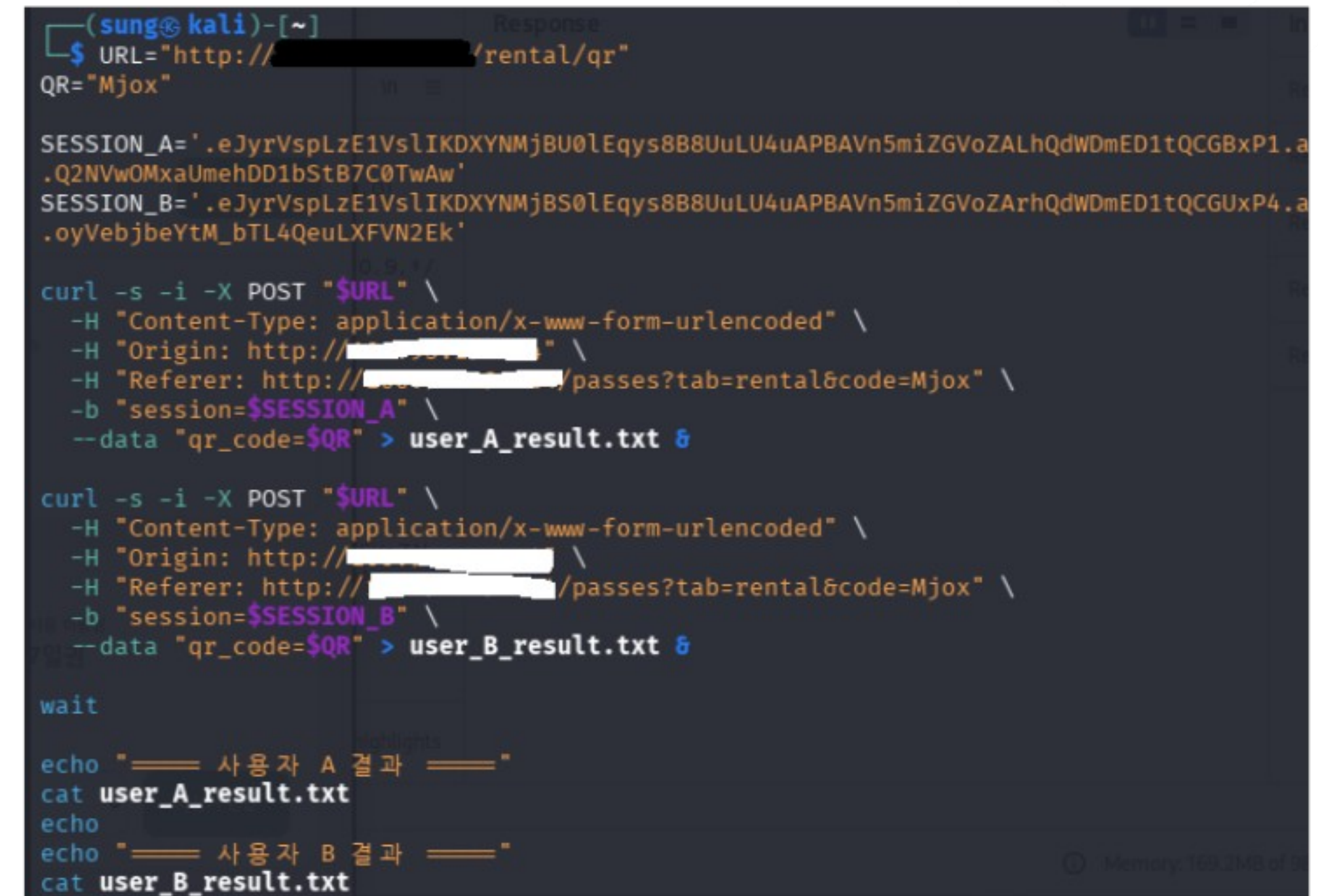
동일한 토큰 변조·재사용 요청을
재수행하여 비정상 대여 차단 확인

03. 시나리오 3.1 - 동일 자전거 동시 중복 대여



1. 취약 진단

서로 다른 사용자 세션에서 동일 자전거에
동시 대여 요청을 전송하여 중복 처리 여부 확인



2. 원인 및 영향 분석

동시성 제어와 자전거 상태 검증 미흡으로
동일 자전거의 중복 대여 발생 가능

03. 시나리오 3.2 - 보안 이벤트 탐지 및 로그 분석

```

{
  "timestamp": "2026-08-03T05:37:34.022+0000",
  "agent": "ttorongi-web",
  "rule_id": "120032",
  "rule_level": 10,
  "description": "[TTORONGI-03][A03][DB] 동시 대여 처리 중 데이터베이스 데드락 탐지",
  "event_type": "rental_error",
  "user_id": "125",
  "bicycle_id": "16",
  "rental_id": null,
  "source_ip": "192.168.10.1",
  "request_path": "/rental/qr",
  "result": "failure",
  "error_type": "OperationalError",
  "error_message": "(1213, 'Deadlock found when trying to get lock; try restarting transaction')",
  "full_log": "{\n  \"timestamp\": \"2026-08-03T05:37:32.426+00:00\",
  \"service\": \"ttorongi-use\",
  \"category\": \"system\",
  \"event_type\": \"rental_error\",
  \"severity\": \"error\",
  \"result\": \"failure\",
  \"source_ip\": \"192.168.10.1\",
  \"message\": \"자전거 대여 처리 중 오류 발생\",
  \"user_id\": 125,
  \"bicycle_id\": 16,
  \"station_id\": 2,
  \"request_path\": \"/rental/qr\",
  \"http_method\": \"POST\",
  \"error_type\": \"OperationalError\",
  \"error_message\": \"(1213, 'Deadlock found when trying to get lock; try restarting transaction')\"
}"
}

```

Aug 3, 2026 @ 14:37:34.022	ttorongi-web	[TTORONGI-03][A03][DB] 동시 대여 처리 중 데이터베이스 데드락 탐지	10	120032
Aug 3, 2026 @ 14:37:32.425	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 14:37:32.423	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 14:37:32.419	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029
Aug 3, 2026 @ 14:37:32.416	ttorongi-snort	[TTORONGI-02][A02][Snort] QR 대여 요청 통신 탐지	11	120029

3. 탐지 이벤트 확인

동일 자전거에 대한 동시 요청과 처리 오류가
Wazuh 상관 이벤트로 탐지됨

data.timestamp	Aug 3, 2026 @ 14:37:32.426
data.bicycle_id	16
data.event_type	rental_error
data.message	자전거 대여 처리 중 오류 발생
data.request_path	/rental/qr
data.user_id	125
data.result	failure
data.error_type	OperationalError
data.error_message	(1213, 'Deadlock found when trying to get lock; try restarting transaction')
data.source_ip	192.168.10.1
data.station_id	2

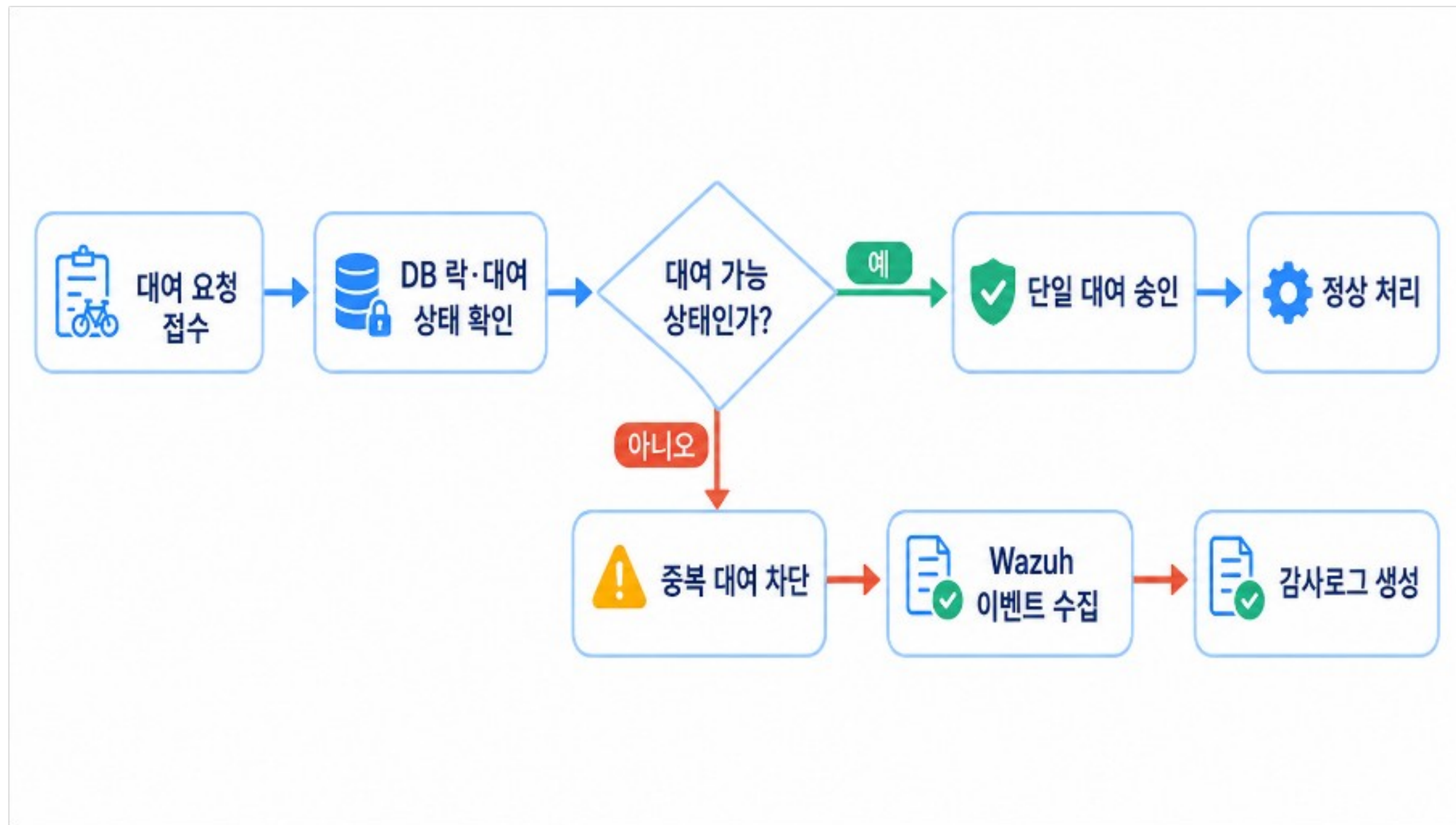
rule.description	[TTORONGI-03][A03][DB] 동시 대여 처리 중 데이터베이스 데드락 탐지
rule.id	120032
rule.level	10
rule.groups	ttorongi_scenario03, a03, race_condition, ttorongi, A03, race_condition, database_deadlock, attack_detected
agent.name	ttorongi-web
agent.ip	100.77.91.115

4. 로그 상세 분석

사용자별 동시 요청과 데이터베이스 처리
오류를

연계하여 중복 대여 시도 원인 분석

03. 시나리오 3.3 - 보안 조치 적용 및 재검증



5. 보안 조치 적용

트랜잭션과 행 잠금 기반 동시성 제어를 적용하여
동일 자전거의 중복 대여 방지

```

MariaDB [bike_core]> SELECT
->     bicycle_id,
->     COUNT(*) AS active_rental_
-> FROM rentals
-> WHERE bicycle_id = 16
->     AND status = 'renting'
->     AND return_time IS NULL
-> GROUP BY bicycle_id;
  
```

bicycle_id	active_rental_count
16	1

1 row in set (0.001 sec)

6. 동일 요청 재검증

동일한 동시 요청을 재수행하여
활성 대여가 1 건만 생성됨을
확인

03. 시나리오 4.1 - 운영자료 비인증 다운로드

또롱이 공공자전거 통합운영기관
협력업체 업무 포털

● 운영 시스템 정상 박정비 담당자
또롱이 정비서비스

TASK INFORMATION
작업 요청 정보

고장 및 점검 내용

월간 정기점검 대상 대여소입니다.

관리자 요청사항

거치대, 안내판, 주변 시설 및 대여소 운영 상태를 점검해 주세요.

작업 유형	우선순위
정기점검	일반
배정 일시	현재 상태
2026.07.25 08:23	처리 완료

1. 취약 진단

인증되지 않은 상태에서 운영자료 경로에
직접 접근하여 다운로드 가능 여부 확인

```
(sung@kali)-[~]  
$ curl -i \  
  http://[REDACTED]/static/exports/maintenance_work_orders.csv  
HTTP/1.1 200 OK  
Server: gunicorn  
Date: Fri, 31 Jul 2026 04:07:56 GMT  
Connection: keep-alive  
Content-Disposition: inline; filename=maintenance_work_orders.csv  
Content-Type: text/csv; charset=utf-8  
Content-Length: 1890  
Last-Modified: Wed, 29 Jul 2026 06:50:13 GMT  
Cache-Control: no-cache  
ETag: "1785307813.6764941-1890-2273450683"  
Accept-Ranges: bytes  
Vary: Cookie
```

2. 원인 및 영향 분석

파일 다운로드 경로에 인증 · 인가 검증이 없어
내부 운영자료가 외부에 노출될 수 있음

03. 시나리오 4.2 - 보안 이벤트 탐지 및 로그 분석

```
{
  "timestamp": "2026-08-03T06:26:41.138+0000",
  "rule_id": "114301",
  "level": 10,
  "description": "[A05] 인증 절차를 우회한 외부 요청으로
  자전거 정비 작업자료가 노출됨",
  "agent": "ttorongi-web",
  "source_ip": "100.125.88.113",
  "method": "GET",
  "request_path": "/static/exports/maintenance_work_order
  s.csv",
  "status_code": "200"
}
```

🔍	Aug 3, 2026 @ 15:26:41.138	ttorongi-web	[A05] 인증 절차를 우회한 외부 요청으로 자전거 정비 작업자료가 노출됨	10	114301
🔍	Aug 3, 2026 @ 15:26:30.910	logserver	TTORONGI pfSense blocked network traffic	5	100521
🔍	Aug 3, 2026 @ 15:26:18.835	logserver	TTORONGI pfSense blocked network traffic	5	100521
🔍	Aug 3, 2026 @ 15:26:15.795	logserver	TTORONGI pfSense blocked network traffic	5	100521
🔍	Aug 3, 2026 @ 15:26:15.794	logserver	TTORONGI pfSense blocked network traffic	5	100521
🔍	Aug 3, 2026 @ 15:26:05.644	logserver	TTORONGI pfSense blocked network traffic	5	100521

3. 탐지 이벤트 확인

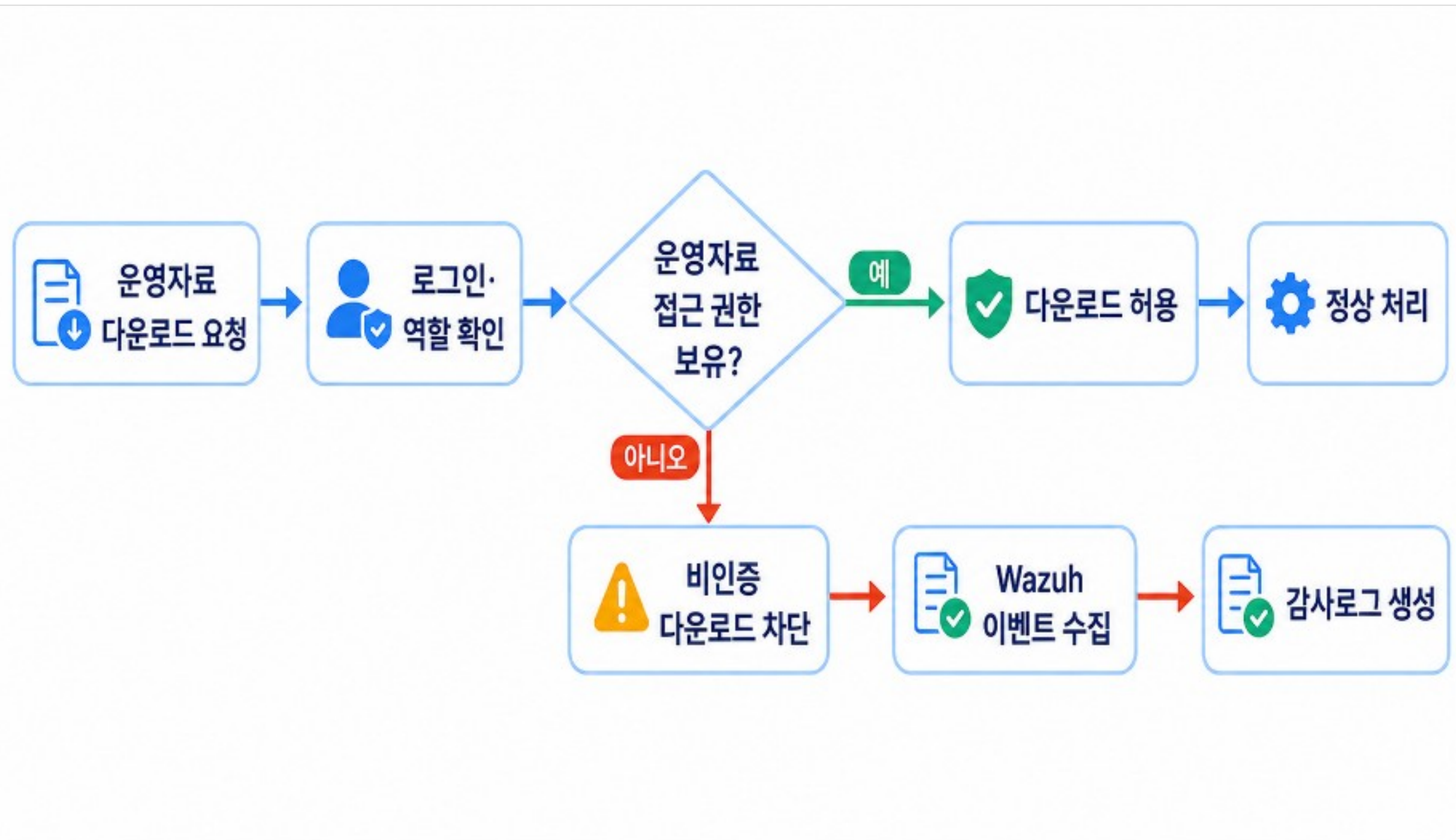
비인증 운영자료 접근 요청이 보안 장비에서 탐지되어 Wazuh 로 통합 수집됨

_index	wazuh-alerts-4.x-2026.08.03
agent.id	001
agent.ip	100.77.91.115
agent.name	ttorongi-web
data.id	200
data.protocol	GET
data.srcip	100.125.88.113
data.url	/static/exports/maintenance_work_orders.csv
decoder.name	web-accesslog
full_log	100.125.88.113 - - [03/Aug/2026:06:26:41 +0000] "GET /static/expor ts/maintenance_work_orders.csv HTTP/1.1" 200 0 "-" "curl/8.19.0"
id	1785738401.4379592
input.type	log
location	/var/log/ttorongi/partner_access.log
manager.name	logserver
rule.description	[A05] 인증 절차를 우회한 외부 요청으로 자전거 정비 작업자료가 노출됨
rule.firedtimes	1
rule.groups	ttorongi, scenario4, a05, sensitive_operational_data_exposure
rule.id	114301
rule.level	10
rule.mail	false
timestamp	Aug 3, 2026 @ 15:26:41.138

4. 로그 상세 분석

요청 경로와 인증 여부를 기준으로
정상 요청과 비인증 다운로드 시도를
구분

03. 시나리오 4.3 - 보안 조치 적용 및 재검증



5. 보안 조치 적용

파일 요청 시 인증·인가 검증을 적용하고
정적 경로를 통한 직접 접근 제한

```

(sung@kali)-[~]
$ curl -i \
  http://[redacted]/static/exports/maintenance_w
HTTP/1.1 403 Forbidden
Date: Fri, 31 Jul 2026 13:33:57 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Length: 280
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at [redacted]</address>
</body></html>
  
```

6. 동일 요청 재검증

동일한 비인증 다운로드 요청을 재수행하여
운영자료 접근 차단 확인

03. 시나리오 5.1 - 운영정보 변경 및 감사로그 미기록

도움이 공공자전거 통합운영기관
정보보안운영부 관리자 시스템

최고관리자 권한으로 접속 중

← 자전거 목록

BICYCLE DETAIL
BIKE-026
QR MzI6NQ== · 정계광장 대여소

대여 가능

자전거 정보 수정

누적 대여: 0 건, 총 이용 시간: 0 분, 누적 이용 금액: 0 원, 현재 배터리: 62 %

BICYCLE INFORMATION
자전거 정보

관리 번호	32
자전거 코드	BIKE-026
QR 코드	MzI6NQ==
배차 대여소	정계광장 대여소 · STATION-05
자전거 상태	대여 가능
배터리	62 %
최근 검증	2026-07-24 07:36:05

CURRENT RENTAL
현재 이용 상태

현재 이 자전거를 이용 중인 사용자가 없습니다.

BICYCLE CONFIGURATION
자전거 정보 수정
자전거 식별 정보와 현재 운영 상태를 설정합니다.

IDENTIFICATION
식별 정보

자전거 코드 필수 QR 코드 필수

BIKE-026 MzI6NQ==

영도, 대문기, 공터, 책이로, 통영을 사용할 수 없습니다. 차량과 QR 코드가 일치하지 않아 차량이나 스테이션에 없습니다.

OPERATION SETTINGS
운영 설정

타계 대여소 자전거 상태 필수

정계광장 대여소 · 6/12대 · 정상 대여 가능

운영 중단 또는 수동정지 기록은 대여소에는 표시되지 않습니다.

배터리 필수 최근 검증

62% 2026-07-24 07:36:05

배터리가 10% 미만이면 대여 가능 상태로 설정할 수 없습니다.

대여 가능 정비 중 고장 배터리 확인된 차량 작업 예정된 상태입니다. 점검이 필요한 차량을 10분 이상 정지된 상태입니다.

1. 취약 진단

관리자 · 협력업체 계정으로 자전거 상태를 변경하고

변경 행위의 감사기록 생성 여부 확인

Request

Pretty Raw Hex

```

1 POST /bicycles/32/edit HTTP/1.1
2 Host: ...
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 147
9 Origin: http://...
10 Connection: keep-alive
11 Referer: http://... 6001/bicycles/32/edit
12 Cookie: session=eyJndWVzdF9tY2RlIjpbOcnVLCJndWVzdF90b2t1biI6IjgxNTI3MGQ0MmYwNWYyM2Q1LCJlc2V5X2lkIjoxMzB9.amwMDg.Jp_nV7xPHMxH0kAhlC8QIngKxgA; ttorongi_admin_session=eyJfY3NyZl90b2t1biI6IiNFS2FfRGoyT3ZTWHQ1bFNSNWYyOWNsX2JhVlhsNnZTYVBXWDJMa18lNXciLCJfcGVyYmFuZW50IjpbOcnVLCJhZG1pbl9pZCI6NDJ9.amwjGA.TyVWOhdwhl28e_AgiQrT62KhmzQ
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 _csrf_token=SEKa_Dj20vSxt5lSR5b29cl_baVXl6vSaPWx2Lj_55w&bicycle_code=BIKE-026&qrcode=MzI6NQ%3D%3D&station_id=5&status=maintenance&battery_level=62
  
```

2. 원인 및 영향 분석

운영정보 변경 행위에 대한 감사로그가 없어
변경 주체와 원인 추적이 어려움

03. 시나리오 5.2 - 보안 로그 적용 및 탐지 결과

```
{
  "timestamp": "2026-08-03T06:56:23.679+00:00",
  "service": "ttorongi-admin",
  "category": "audit",
  "event_type": "bike_status_changed",
  "severity": "info",
  "result": "success",
  "source_ip": "192.168.10.1",
  "message": "관리자 자전거 상태 변경 ",
  "admin_id": 42,
  "user_id": 42,
  "username": "admin",
  "actor_user_id": 42,
  "actor_username": "admin",
  "actor_role": "admin",
  "department_code": "information_security",
  "department_name": "정보보안운영부",
  "permission_code": "super_admin",
  "permission_name": "최고관리자",
  "bicycle_id": 32,
  "bicycle_code": "BIKE-026",
  "old_status": "maintenance",
  "previous_status": "maintenance",
  "new_status": "available",
  "change_reason": "관리자 사이트 자전거 정보 수정 ",
  "request_path": "/bicycles/32/edit",
}
```

Aug 3, 2026 @ 16:00:51.740	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401
Aug 3, 2026 @ 16:00:50.991	logserver	TTORONGI pfSense blocked network traffic	5	100521
Aug 3, 2026 @ 16:00:49.991	logserver	TTORONGI pfSense blocked network traffic	5	100521
Aug 3, 2026 @ 16:00:47.905	ttorongi-waf	Agent event queue is back to normal load.	3	205
Aug 3, 2026 @ 16:00:44.286	ttorongi-snort	Snort IDS/IPS network detection alert	7	100500

3. 탐지 이벤트 확인

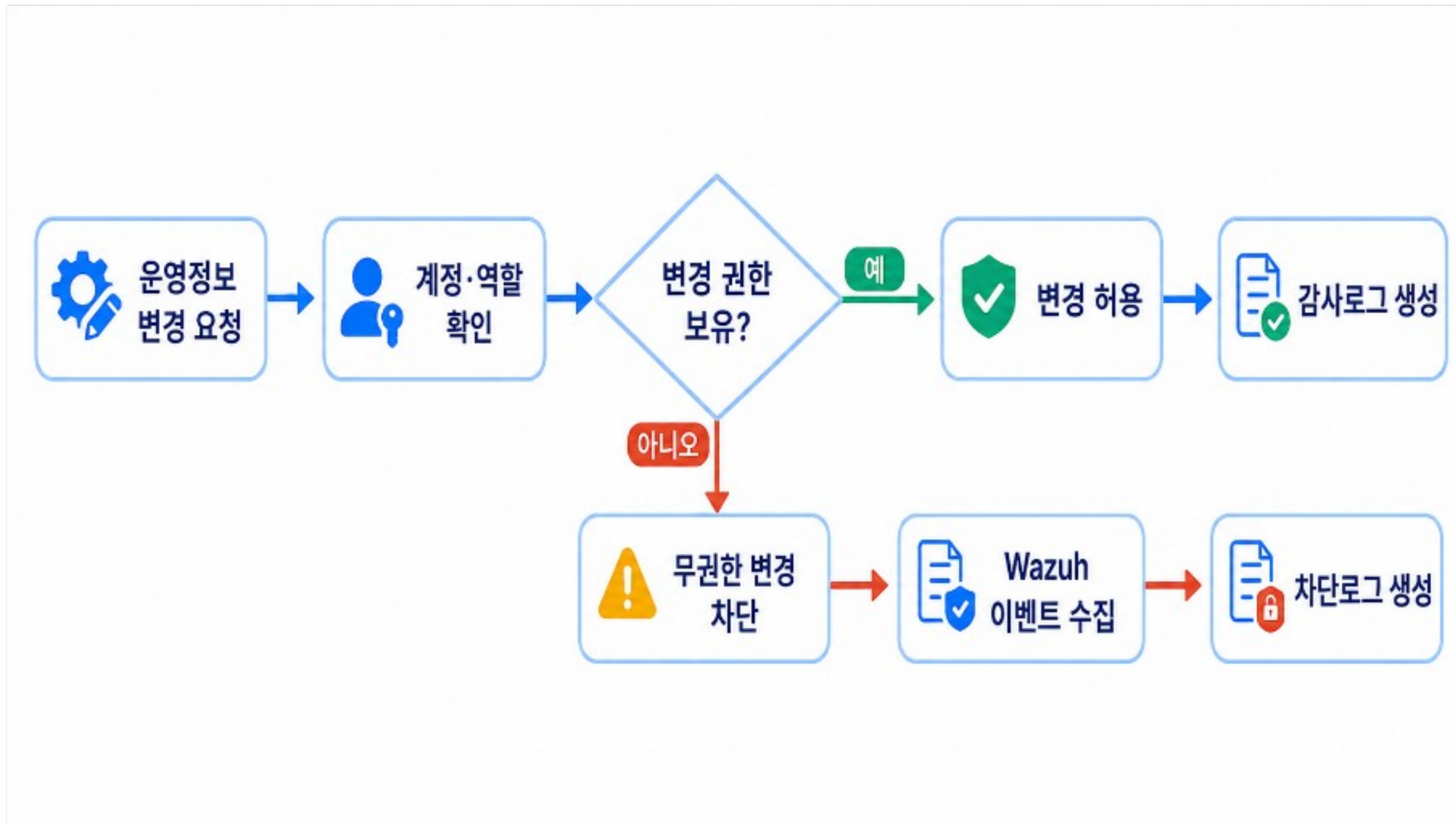
자전거 상태 변경 행위가 감사 이벤트로
기록되어 Wazuh 에 수집됨

agent.name	logserver
agent.id	000
data.access_timestamp	2026-08-03T07:00:43.856+0000
data.agent_name	ttorongi-web
data.category	security
data.event_type	operational_change_without_audit_context
data.http_method	POST
data.message	파트너 자전거 상태 변경 요청 이후 bike_status_changed 감사로그가 확인되지 않음
data.request_path	/partner/bicycle/status
data.result	success
data.service	ttorongi-wazuh
data.severity	high
data.source_ip	192.168.10.2
data.timestamp	Aug 3, 2026 @ 16:00:50.970
decoder.name	json
location	/var/log/ttorongi/scenario5_missing_audit.json
manager.name	logserver
rule.description	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함
rule.groups	ttorongi, scenario5, a09, insufficient_audit_context
rule.id	114401
rule.level	8
timestamp	Aug 3, 2026 @ 16:00:51.740

4. 로그 상세 분석

변경 주체 · 대상 · 시각 · 변경 전후
값을
기록하여 운영정보 변경 이력을 추적

03. 시나리오 5.3 - 보안 조치 적용 및 재검증



5. 보안 조치 적용

운영정보 변경 시 권한을 검증하고
변경 전후 정보를 포함한 감사로그 생성

```

{
  "timestamp": "2026-08-03T06:56:23.679+00:00",
  "service": "ttorongi-admin",
  "category": "audit",
  "event_type": "bike_status_changed",
  "result": "success",
  "actor_user_id": 42,
  "actor_username": "admin",
  "actor_role": "admin",
  "department_name": "정보보안운영부",
  "permission_name": "최고관리자",
  "bicycle_id": 32,
  "bicycle_code": "BIKE-026",
  "previous_status": "maintenance",
  "new_status": "available",
  "change_reason": "관리자 사이트 자전거 정보 수정",
  "source_ip": "192.168.10.1",
  "request_path": "/bicycles/32/edit",
  "http_method": "POST"
}
  
```

6. 동일 요청 재검증

동일한 상태 변경 요청을
재수행하여 감사로그 생성 확인

03. 취약점별 보안 개선 조치

주요 취약점에 대한 보안 개선 조치

2026.08.04 기준

시나리오	확인 취약점	보안 개선 조치
1	타 사용자 대여정보 접근 가능	사용자 · 자원 소유권 검증 및 권한 검사 강화
2	QR 토큰 변조 가능	토큰 무결성 검증 및 일회성 · 만료 처리 적용
3	동일 자전거 중복 대여	DB 트랜잭션 및 동시성 제어 적용
4	운영자료 비인증 다운로드	인증 · 인가 검증 및 직접 파일 접근 차단
5	운영정보 변경 감사로그 누락	변경 이벤트 감사로그 생성 및 Wazuh 연계

개선 결과

모의해킹을 통해 확인된 취약점의 원인을 분석하고 인증 · 인가 , 무결성 검증 , 동시성 제어 및 감사로그 보강을 수행했습니다 .

03. 주요 취약점 재검증 결과

주요 취약점 보완 내용

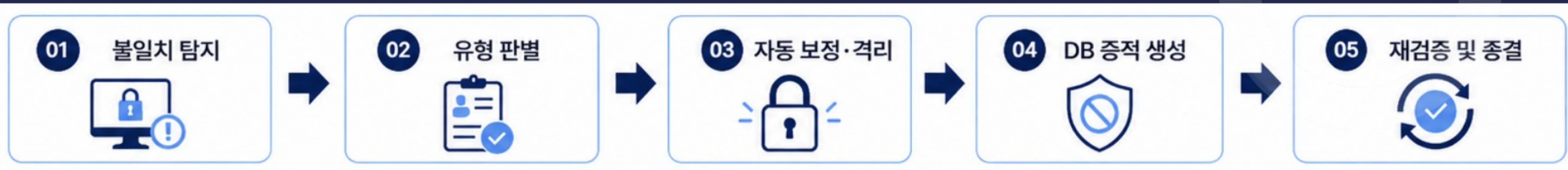
2026.08.04 기준

시나리오	보안 적용 전	적용 보안	동일 공격 재검증	결과
1	타 사용자 정보 조회 가능	소유권 · 권한 검증	동일 ID 변조 요청	차단
2	변조 QR 토큰 허용	토큰 무결성 검증	동일 변조 토큰 요청	차단
3	중복 대여 발생	동시성 제어	동시 요청 재전송	차단
4	비인증 다운로드 가능	인증 · 인가 검증	동일 URL 직접 접근	차단
5	감사로그 미생성	감사로그 기록 적용	운영정보 변경 재수행	로그 생성

재검증 결과

동일한 공격 요청을 재수행한 결과 , 시나리오 1~4 는 비정상 행위가 차단되었으며
시나리오 5 는 변경 이력이 감사로그로 정상 기록되었습니다 .

03. 보안사고 추가대응 자동화 및 복구 검증



검증 1. 활성 대여 상태 불일치

DB 조회 결과 : 자전거 상태 available / 대여 상태

bicycle_id	bicycle_code	bicycle_status	rental_id	rental_status	return_time
37	BIKE-INT-20260803134616	available	80	renting	NULL

탐지 및 복구 이벤트 (메인 증거)

```

{
  "timestamp": "2026-08-03T13:46:16.756+00:00",
  "service": "ttorongi-rental-integrity-watch",
  "category": "data_integrity",
  "event_type": "rental_integrity_violation_detected",
  "severity": "high",
  "result": "detected",
  "message": "대여 기록과 자전거 상태 간 불일치 탐지",
  "issue_key": "active-not-rented:37",
  "issue_type": "active_rental_but_bicycle_not_rented",
  "bicycle_id": 37,
  "bicycle_code": "BIKE-INT-20260803134616",
  "bicycle_status": "available",
  "active_rental_count": 1,
  "active_rental_ids": [
    "80"
  ]
}
  
```

해소 이벤트 (자동 보정 후)

```

{
  "timestamp": "2026-08-03T13:46:18.460+00:00",
  "service": "ttorongi-rental-integrity-watch",
  "category": "data_integrity",
  "event_type": "rental_integrity_recovered",
  "severity": "info",
  "result": "success",
  "message": "기존 대여 자전거 불일치가 해소됨",
  "issue_key": "duplicate-active:37"
}
  
```

- issue_type: active_rental_but_bicycle_not_rented
- bicycle_id: 37 / rental_id: 80
- result: recovery_success

검증 2. 동일 자전거 중복 활성 대여

탐지 및 복구 이벤트 (메인 증거)

```

{
  "timestamp": "2026-08-03T13:46:17.886+00:00",
  "service": "ttorongi-rental-integrity-watch",
  "category": "data_integrity",
  "event_type": "rental_integrity_violation_detected",
  "severity": "critical",
  "result": "detected",
  "message": "대여 기록과 자전거 상태 간 불일치 탐지",
  "issue_key": "duplicate-active:37",
  "issue_type": "duplicate_active_rentals",
  "bicycle_id": 37,
  "bicycle_code": "BIKE-INT-20260803134616",
  "bicycle_status": "rented",
  "active_rental_count": 2,
  "active_rental_ids": [
    "80",
    "81"
  ]
}
  
```

- issue_type: duplicate_active_rentals
- active_rental_count: 2
- active_rental_ids: 80, 81

04

SECURITY ANALYSIS
& MONITORING

악성코드 분석 및 대응방안

분석용 악성코드의 정적·동적 행위를 분석하고,
주요 위험에 대한 대응방안을 도출했습니다.

01

샘플 제작 및 실행

Python 기반 분석용 악성코드 제작 및 실행

02

정적·동적 분석

파일 구조·시스템 행위·프로세스 동작 분석

03

분석 결론 및 대응

공격 흐름 도출 및 보안 대응방안 제시

04. 분석용 악성코드 제작 및 실행

제작 및 빌드

이름	수정한 날짜	유형	크기
build	2026-07-29 오후 4:33	파일 폴더	
dist	2026-07-29 오후 4:36	파일 폴더	
ttorongi_malware.py	2026-07-29 오후 1:08	PY 파일	6KB
ttorongi_malware.spec	2026-07-29 오후 4:33	SPEC 파일	1KB
ttorongi_malware.exe	2026-07-29 오후 4:34	응용 프로그램	7,893KB

실행 확인

```

C:\Users\홍기수\Desktop\#ttorongi_malware.exe
TTORONGI SAFE OPERATION TAMPERING SIMULATOR START (WINDOWS VERSION)
[test_qr_token_created] 교육용 가짜 QR 토큰 파일을 생성함
[test_bicycle_state_created] 교육용 자전거 초기 상태 파일을 생성함
[system_information_collected] 비민감 시스템 정보를 기록함
[suspicious_process_execution] 무해한 자식 프로세스를 실행함
  
```



QR 토큰 데이터
생성



상태 파일 생성



시스템 정보 수집



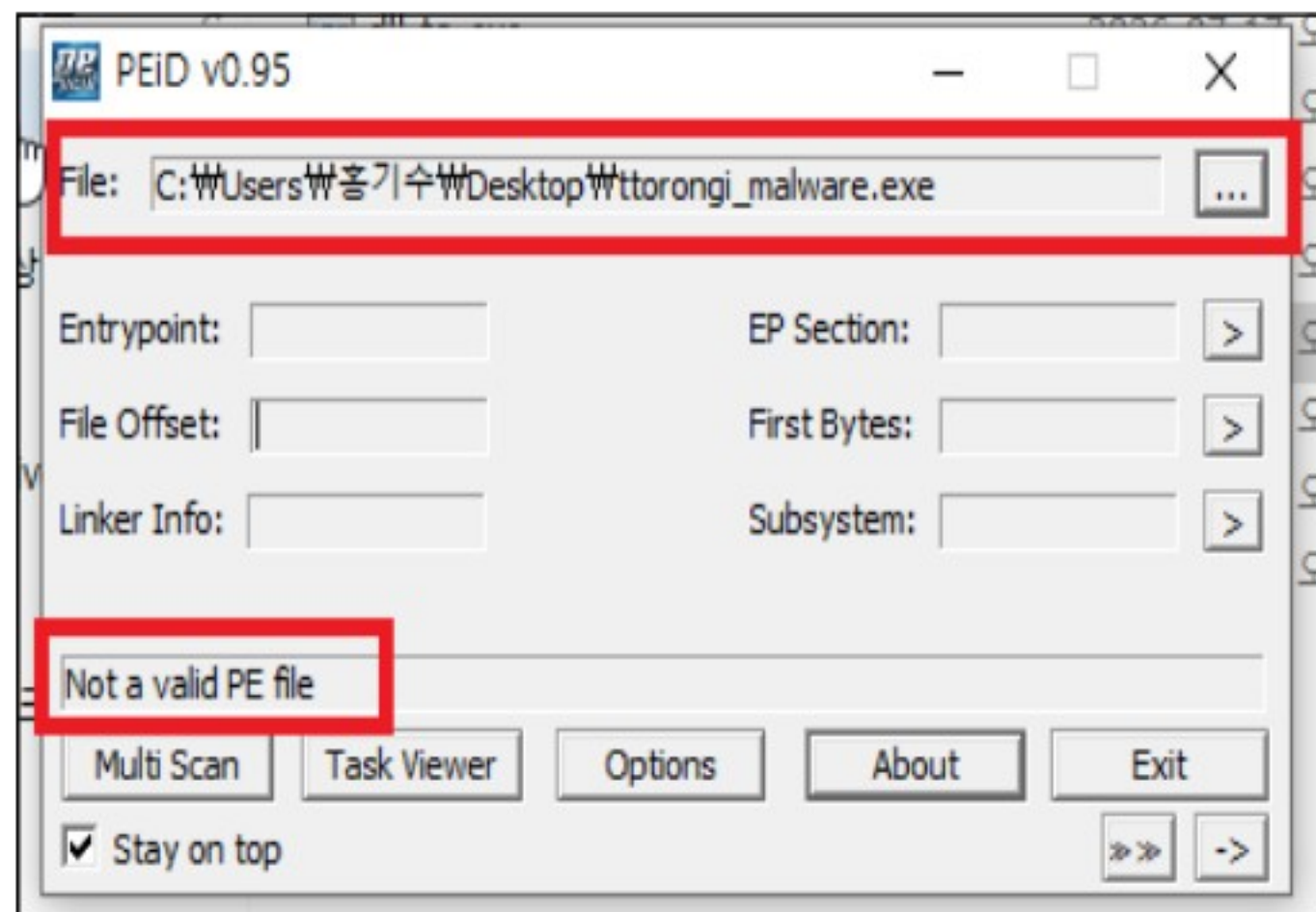
자식 프로세스 실행



분석용 샘플 제작 및 실행 환경 구성

04. 악성코드 정적 분석

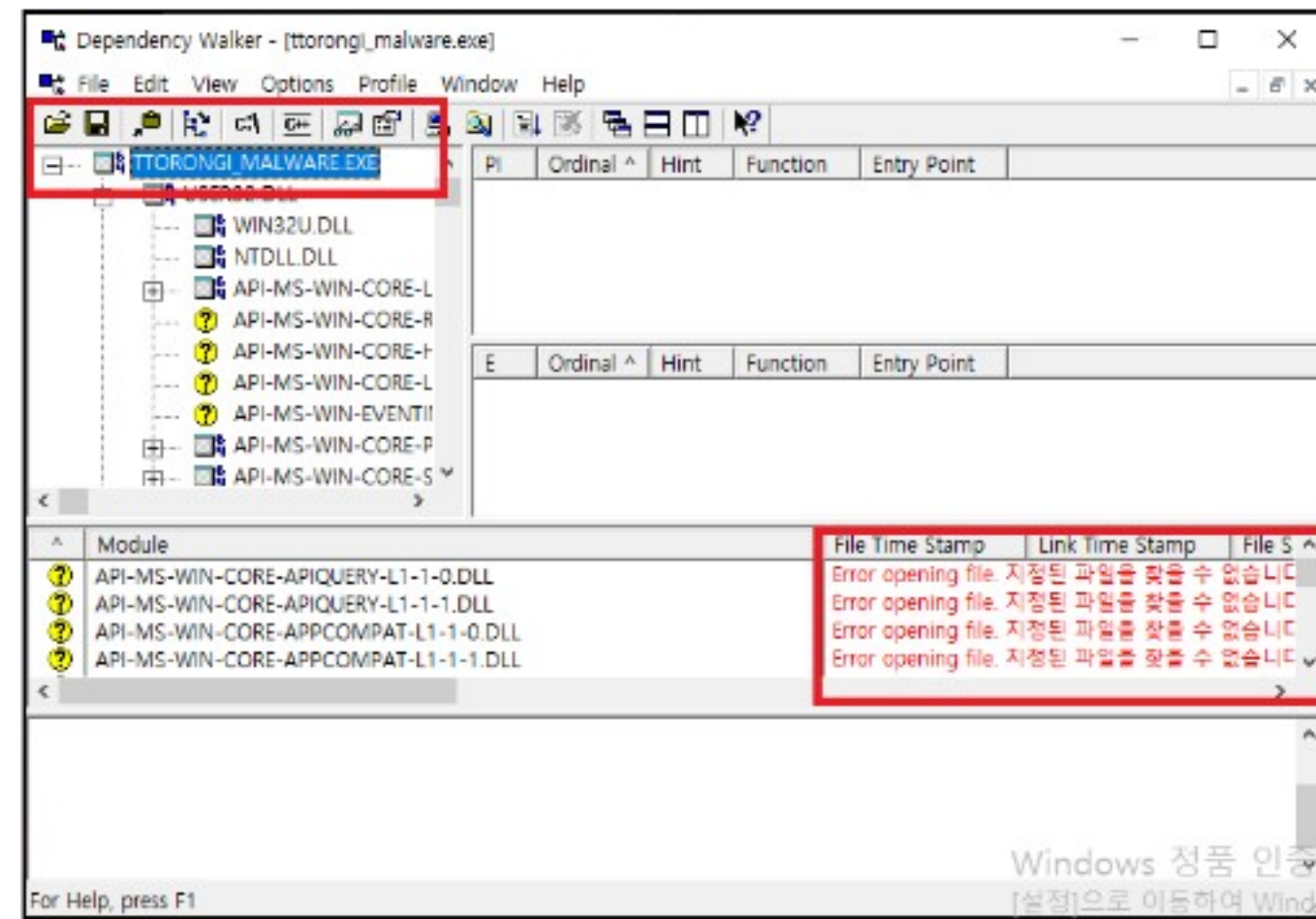
PEID



PyInstaller 패키징 가능성 확인

일반 PE 분석 도구에서 파일 구조가 정상적으로 식별되지 않아 패키징 여부에 대한 추가 분석이 필요

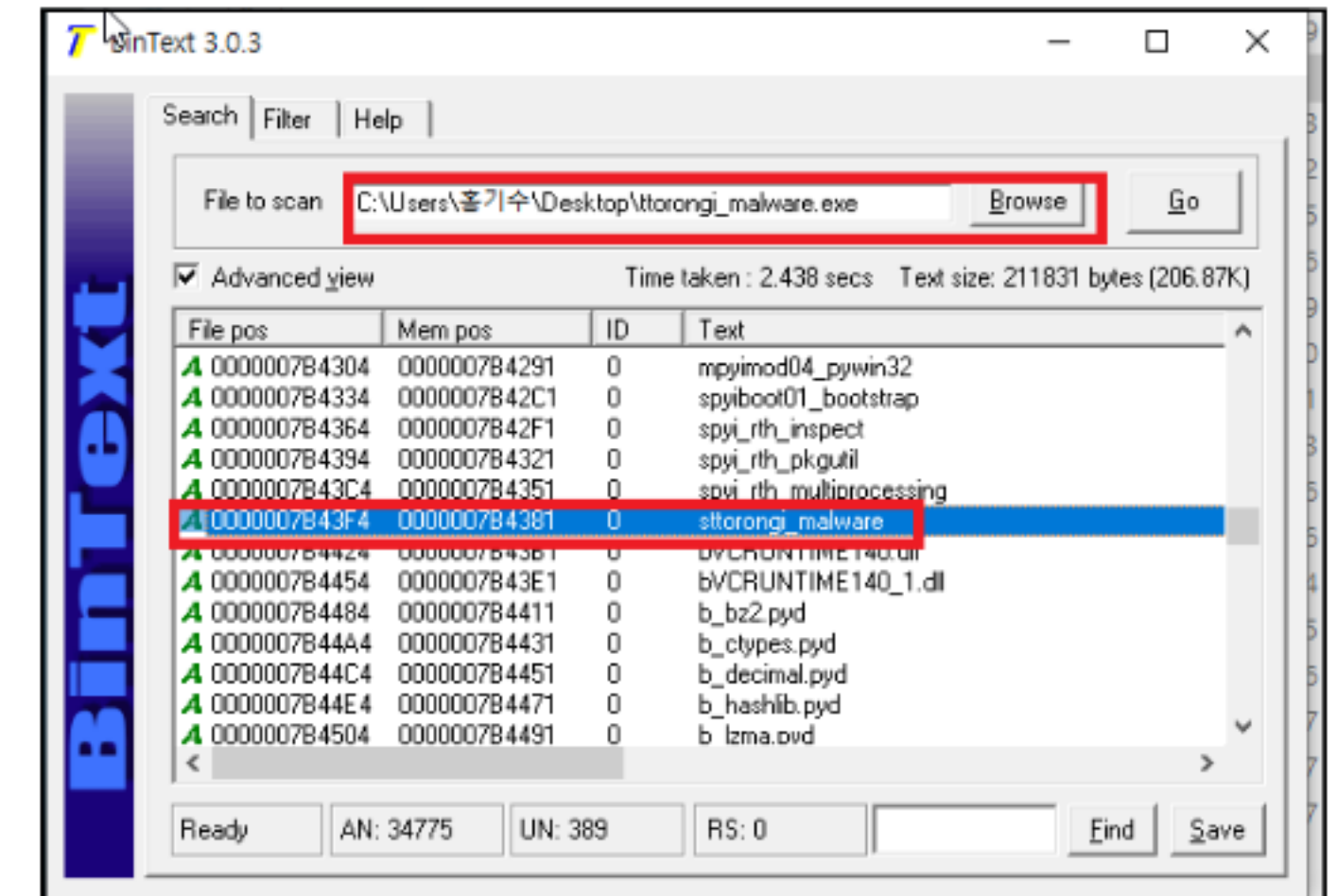
DEPENDENCY WALKER



DLL 의존성 분석 제한 확인

패키징 및 API Set 구조로 인해 일부 DLL 이 정상 식별되지 않음을 확인

BINTEXT



의심 문자열 식별

정적 분석 결과를 기반으로 주요 의심 요소를 식별하고 동적 분석 대상을 선정

정적 분석에서 확인한 의심 요소를 바탕으로 동적 분석 대상을 선정했습니다 .

04. 악성코드 동적 분석

Process Explorer

Time...	Process Name	PID	Operation	Path	Result	Detail
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\Users\홍기수\AppData\Loc...	NAME NOT FOU...	Desired Access...
오후 9:...	ttorongi_mal...	1448	QueryInforma...	C:\ttorongi-malware-lab\simulat...	SUCCESS	VolumeCreation...
오후 9:...	ttorongi_mal...	1448	QueryAllInfor...	C:\ttorongi-malware-lab\simulat...	BUFFER OVERF...	CreationTime: 2...
오후 9:...	ttorongi_mal...	1448	QueryBasicIn...	C:\ttorongi-malware-lab\simulat...	SUCCESS	CreationTime: 2...
오후 9:...	ttorongi_mal...	1448	QueryIdInfor...	C:\ttorongi-malware-lab\simulat...	SUCCESS	AllocationSize: ...
오후 9:...	ttorongi_mal...	1448	QueryStanda...	C:\ttorongi-malware-lab\simulat...	SUCCESS	AllocationSize: ...
오후 9:...	ttorongi_mal...	1448	WriteFile	C:\ttorongi-malware-lab\simulat...	SUCCESS	Offset: 14,330, L...
오후 9:...	ttorongi_mal...	1448	CloseFile	C:\ttorongi-malware-lab\simulat...	SUCCESS	
오후 9:...	ttorongi_mal...	1448	CreateFile	C:\ttorongi-malware-lab\work\Wt...	SUCCESS	Desired Access...
오후 9:...	ttorongi_mal...	1448	QueryInforma...	C:\ttorongi-malware-lab\work\Wt...	SUCCESS	VolumeCreation...

자전거 상태 JSON 파일의 실제 변조 행위 -----확인-----

분석 근거 : WriteFile 호출 110 건 및 파일 변경 기록 확인

Process Monitor

Process	CPU	Private Byt...	Working Set	PID	Description
Registry		4,512 K	81,132 K	96	
System Idle Process	100,00	60 K	8 K	0	
System	< 0,01	196 K	140 K	4	
Interrupts	< 0,01	0 K	0 K	n/a	Hardware Interrupts and...
svchost.exe		2,160 K	8,076 K	964	Host Process for Windo... Microsoft Corporation
svchost.exe		3,276 K	10,820 K	736	Host Process for Windo... Microsoft Corporation
svchost.exe		5,980 K	15,780 K	1072	Host Process for Windo... Microsoft Corporation
taskhost.exe		5,980 K	15,124 K	4572	Windows 작업 관리자... Microsoft Corporation

CPU Usage: 0.00% Commit Charge: 55.60% Processes: 125 Physical Usage: 68.27%

실행 후 종료되는 단발성 공격 동작 확인

확인 결과 : 실행 직후 데이터 변조를 수행하고 자동 종료

04. 악성코드 분석 결론

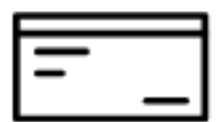
세부 행위



시스템 정보 확인



파일 생성



프로세스 실행

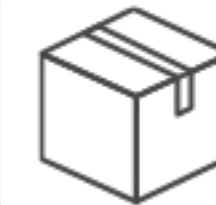


JSON 데이터 변조



파일 삭제

분석 근거



PyInstaller
패킹



백그라운드 프로세스



WriteFile 호출



JSON 변경 기록



운영정보 변조 과정을 재현한 교육용 악성코드 시뮬레이터
실제 정보 탈취 목적이 아닌 정적·동적 분석 및 탐지 검증용 샘플

04. 악성코드 대응 전략



05

PROJECT RESULTS &
IMPROVEMENT

부록 | 추가 자료 및 증적

본문에서 다루지 못한 추가 구축 · 운영 자료와 검증 증적을 정리합니다.

01

보완 자료

서비스 · 인프라 · 보안 설정 관련 보완 자료

02

추가 검증

탐지 · 대응 · 복구 결과 및 실행 증적

03

참고 증적

본문 이해를 돕는 세부 화면 및 보조 증적

05. DNS 응답 및 서비스 연결 검증



01 DNS 응답 확인

- 도메인 : www.ttorongi.com
- DNS 서버 : 100.115.219.46
- 응답 IP : **192.168.219.123** (pfSense)

```

선택 관리자: Windows PowerShell

PS C:\WINDOWS\system32> # 2. 방금 직접 수정한 서버(100.115.219.46)에 주소 물어보기!
PS C:\WINDOWS\system32> Resolve-DnsName www.ttorongi.com -Server 100.115.219.46 -Type A -DnsOnly

Name                Type  TTL  Section  IPAddress
----                -
www.ttorongi.com    A      300  Answer   192.168.219.123 — pfSense IP로 응답
  
```



02 pfSense 경유 접속 확인

- 외부 진입 IP : 100.95.198.24 (Tailscale)
- 포트 : 80
- 결과 : **HTTP/1.1 302 FOUND**

```

PS C:\WINDOWS\system32> curl.exe -I --resolve www.ttorongi.com:80:100.95.198.24 http://www.ttorongi.com
HTTP/1.1 302 FOUND
Date: Mon, 03 Aug 2026 12:21:59 GMT
Server: gunicorn
Content-Type: text/html; charset=utf-8
Content-Length: 199
Location: /guest
Vary: Cookie
  
```

- pfSense 외부 IP로 80번 요청
- 302 응답 수신
- /guest로 리다이렉트



03 내부 서비스 전달 확인

- 웹 서버 : gunicorn
- 리다이렉트 경로 : /guest
- 내부 웹서비스 정상 연결 확인

```

PS C:\WINDOWS\system32> curl.exe -I --resolve www.ttorongi.com:5000:100.95.198.24 http://www.ttorongi.com:5000
0
curl: (28) Failed to connect to www.ttorongi.com:5000 after 21052 ms: Could not connect to server
  
```

- 5000 포트는 외부에서 직접 접근 불가



DNS → pfSense → 내부 웹서비스로 요청이 **정상 전달됨**을 검증

05. 관리자 서비스 - 부서별 메뉴 권한 설정

시설정비부



경영기획부



자전거운영부



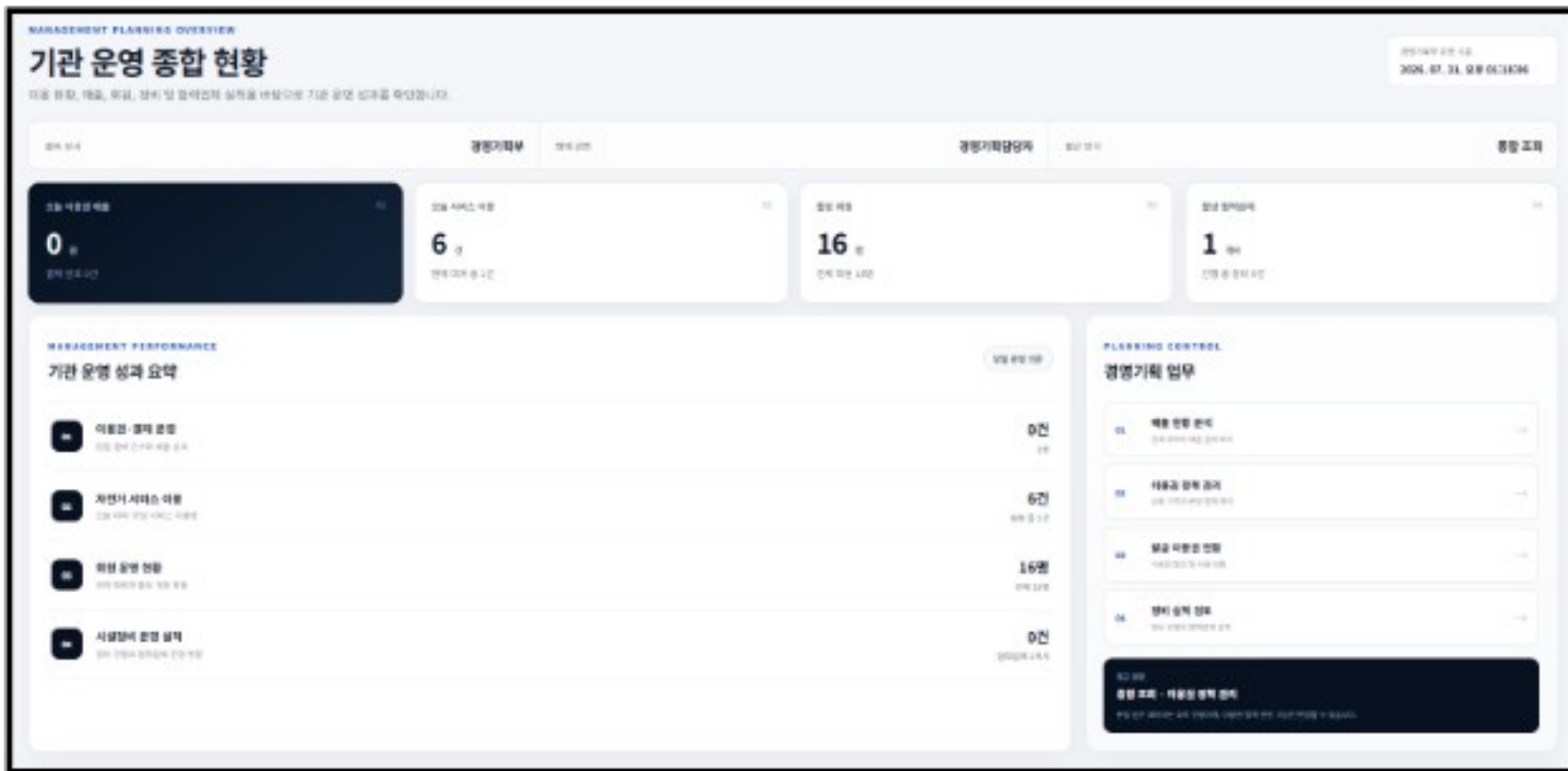
고객서비스부



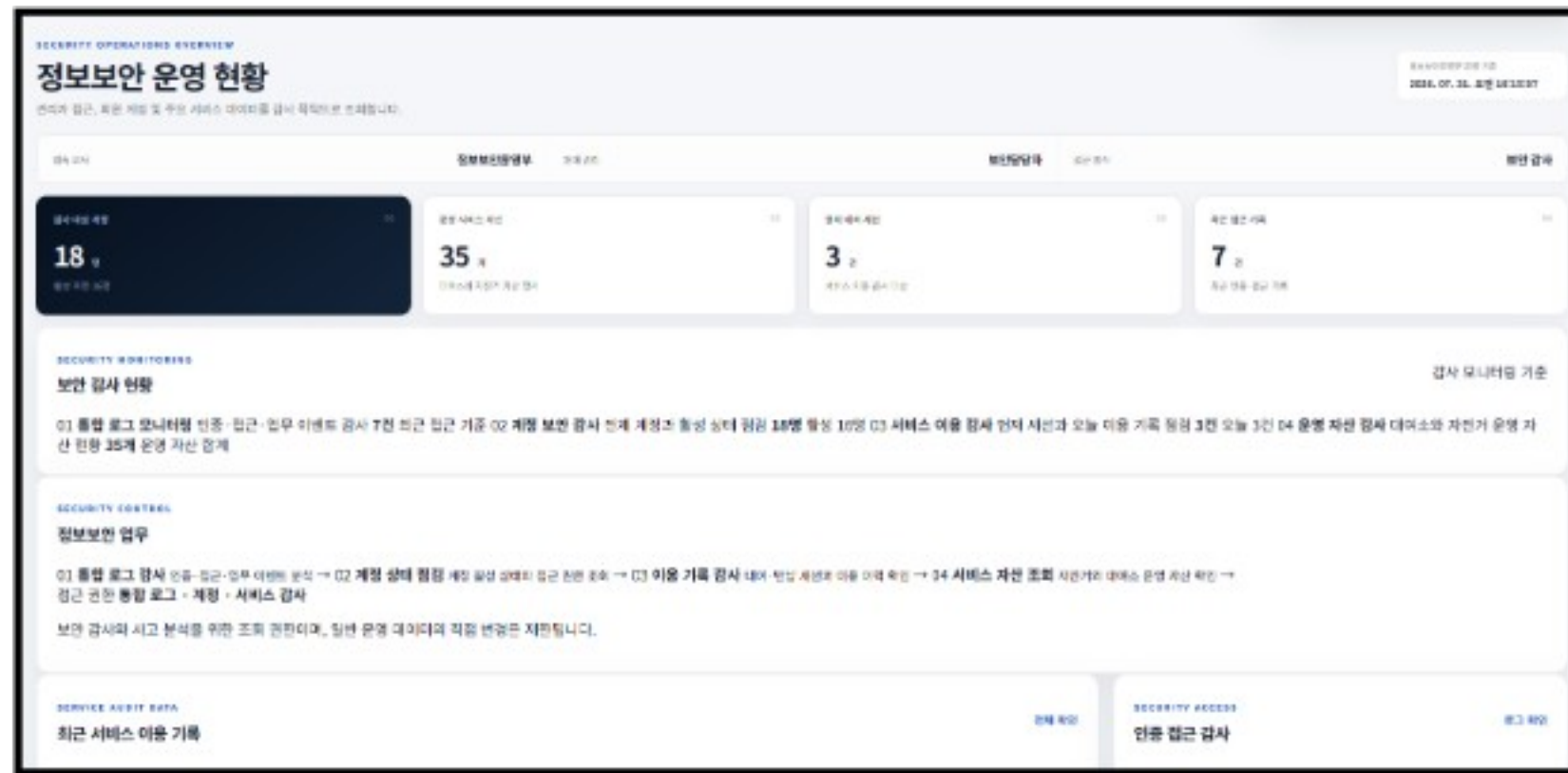
정보보안운영부



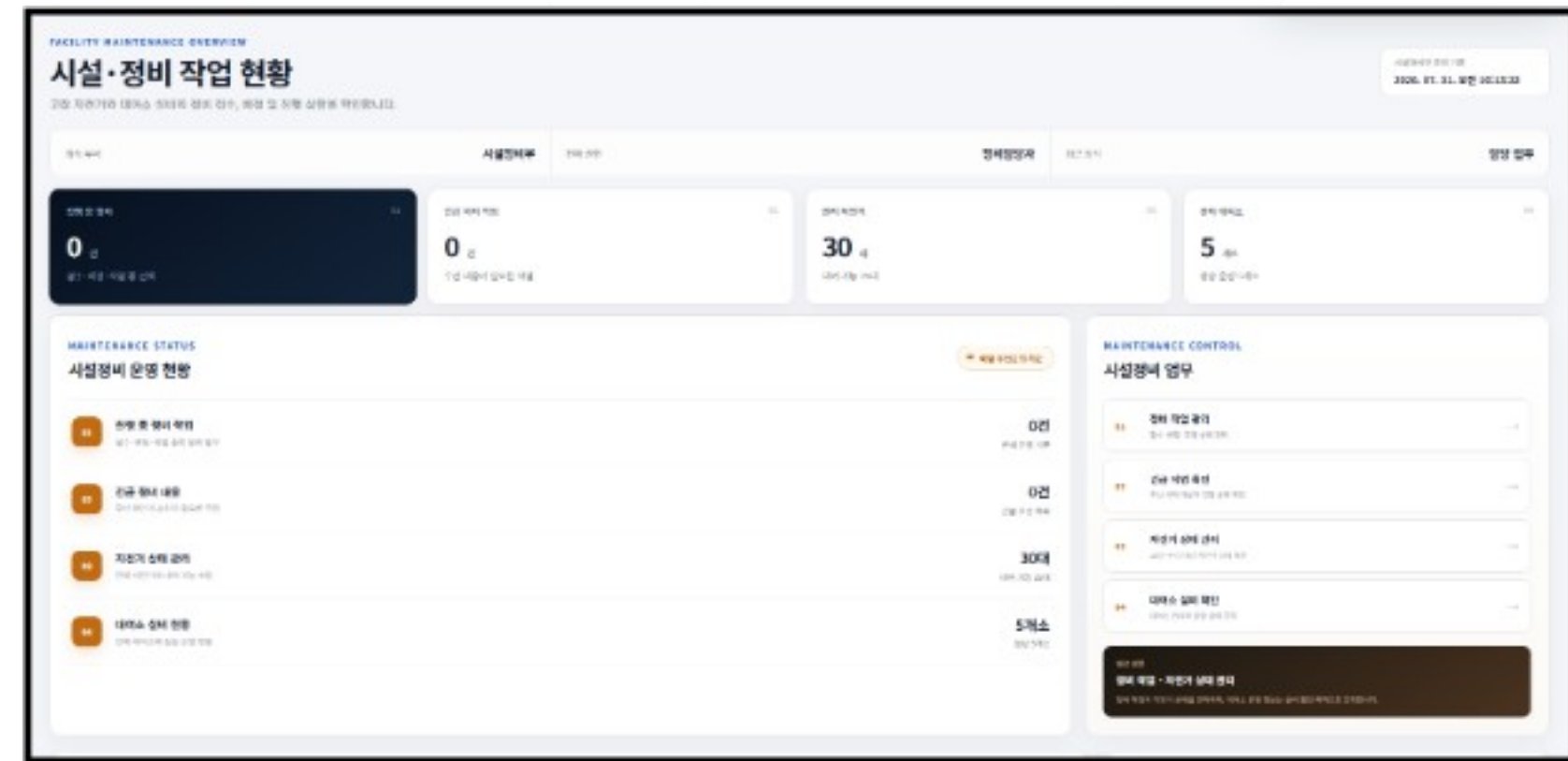
05. 관리자 서비스 - 부서별 대시보드



경영기획부

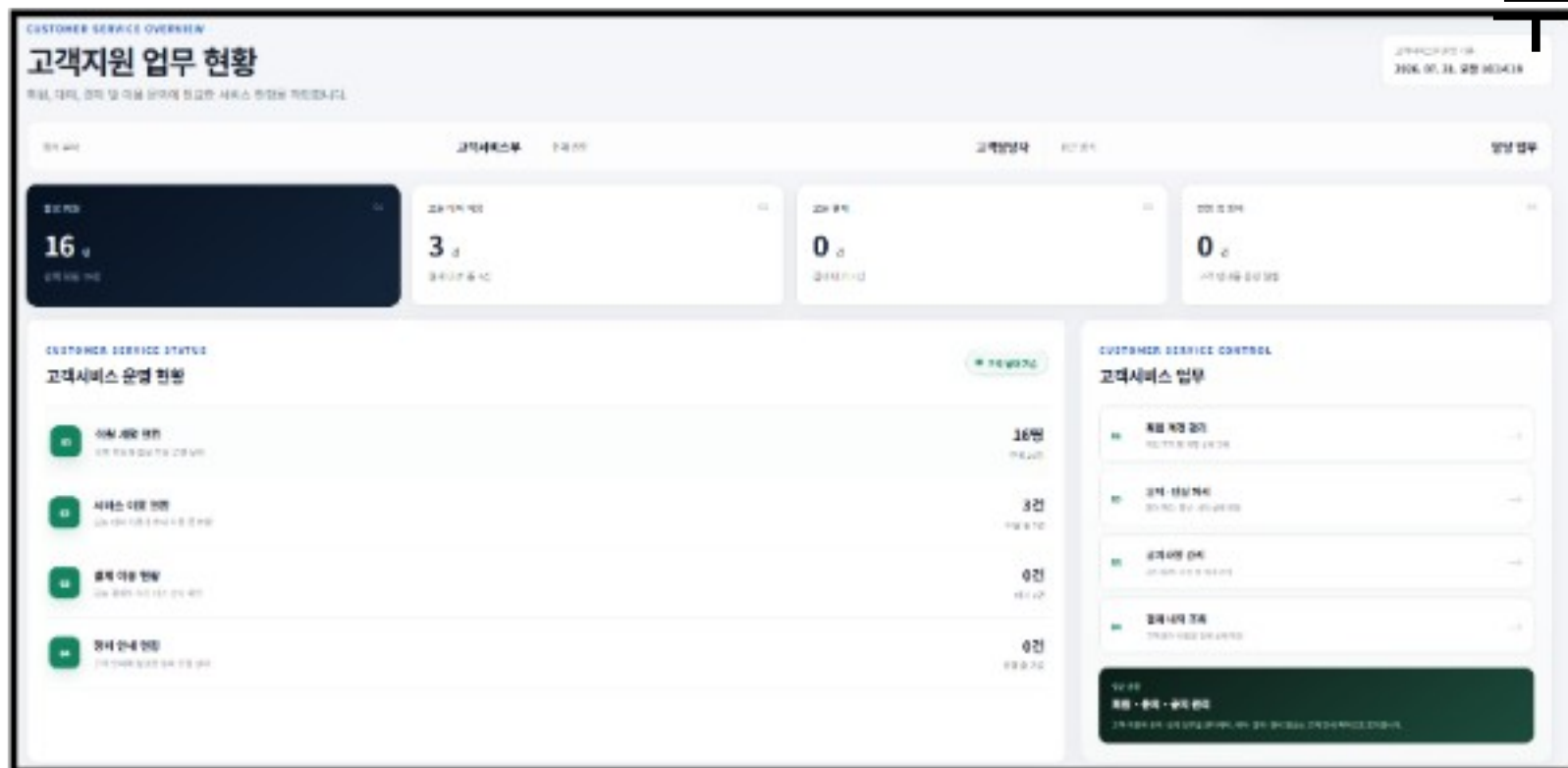


정보보안운영

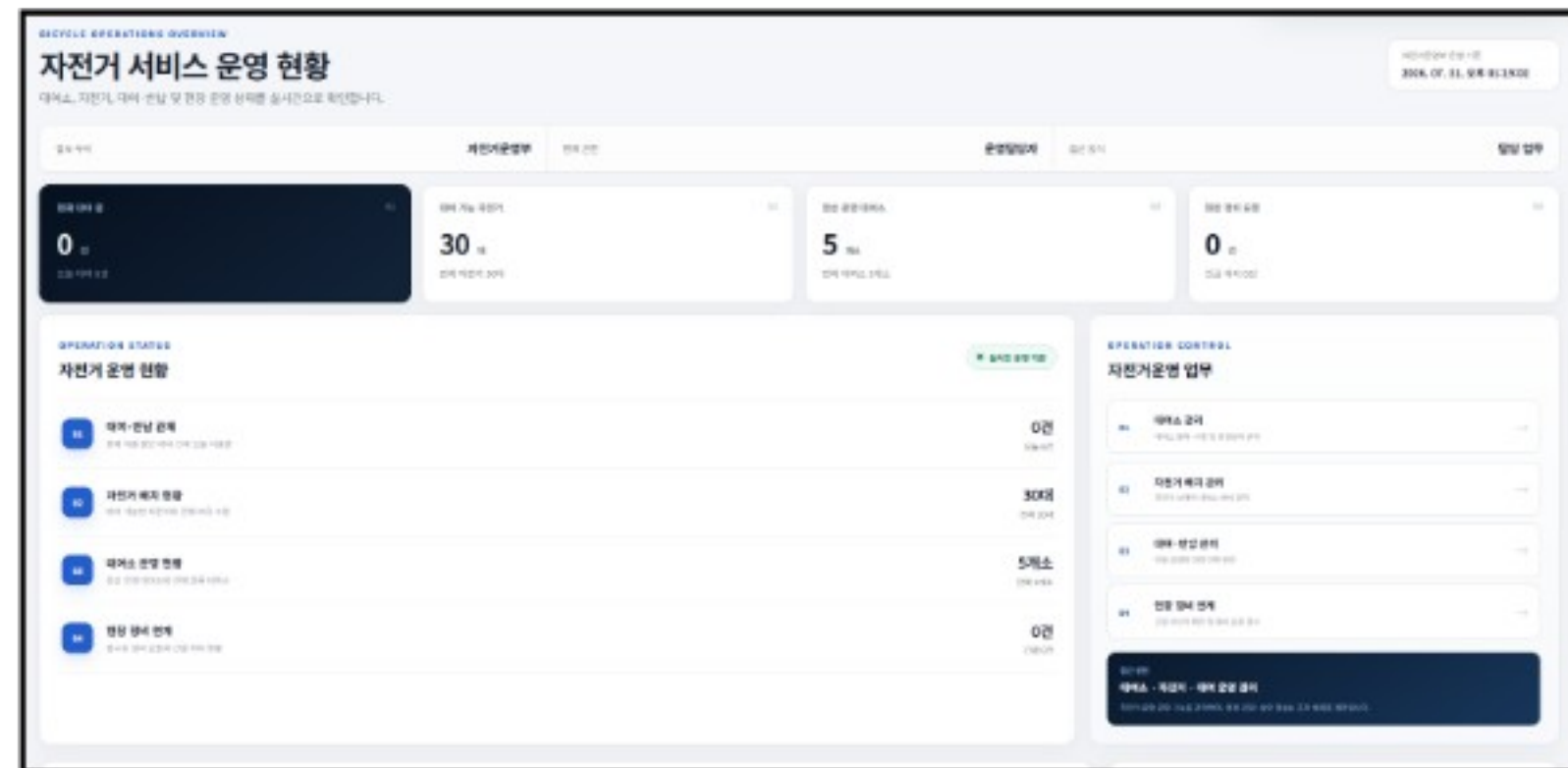


시설정비부

부

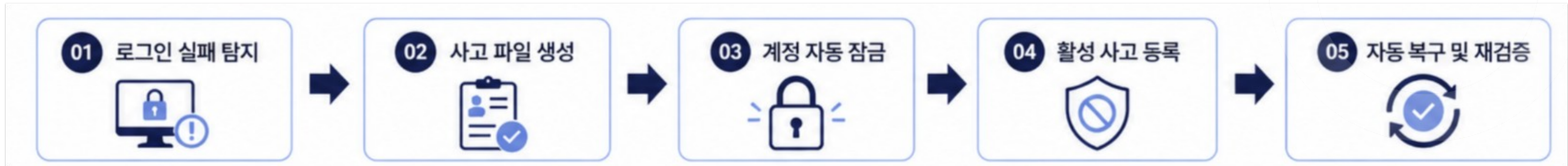


고객서비스부



자전거운영부

05. 보안사고 추가대응 및 복구 검증



사고 파일 생성 확인

```

FILE=/var/log/ttorongi/incidents/INC-20260803-130350-797-user01.json
{
  "incident_id": "INC-20260803-130350-797-user01",
  "status": "open",
  "incident_type": "repeated_login_failure",
  "severity": "high",
  "username": "user01",
  "source_ip": "192.168.10.1",
  "detected_at": "2026-08-03T13:03:50.797+00:00",
  "failure_count": 5,
  "threshold": 5,
  "detection_window_minutes": 10,
  "automated_response": {
    "action": "temporary_account_lock",
    "result": "success",
    "locked_at": "2026-08-03T13:03:50.797+00:00",
    "locked_until": "2026-08-03T13:13:50.797+00:00",
    "lock_minutes": 10
  },
  "blocked_attempts": 2,
  "blocked_attempt_events": [
    {
      "timestamp": "2026-08-03T13:03:53.790+00:00",
      "source_ip": "192.168.10.1",
      "request_path": "/login",
      "http_method": "POST",
      "result": "failure"
    }
  ]
}
  
```

반복 로그인 실패 탐지 후 incident_id, 계정 잠금 여부 및 차단 횟수가 포함된 사고 파일 생성 확인

활성 사고 파일 상태 등록 확인

또롱이
공공자전거 통합운영기관

로그인 실패가 반복되어 계정이 10분간 임시 잠금되었습니다.

```

son",
  "locked_at": "2026-08-03T13:02:46.578+00:00"
},
"user01": {
  "incident_id": "INC-20260803-130350-797-user01",
  "path": "/var/log/ttorongi/incidents/INC-20260803-130350-797-user01.json",
  "locked_at": "2026-08-03T13:03:50.797+00:00"
}
  
```

active_incidents 에 사용자별 사고번호, 파일 경로, 잠금 시각이 정상 등록됨

탐지부터 사고 등록, 계정 잠금, 활성 사고 관리까지 자동 대응 절차가 정상적으로 수행됨을 확인했습니다.

05. Wazuh 기반 로그 대시보드

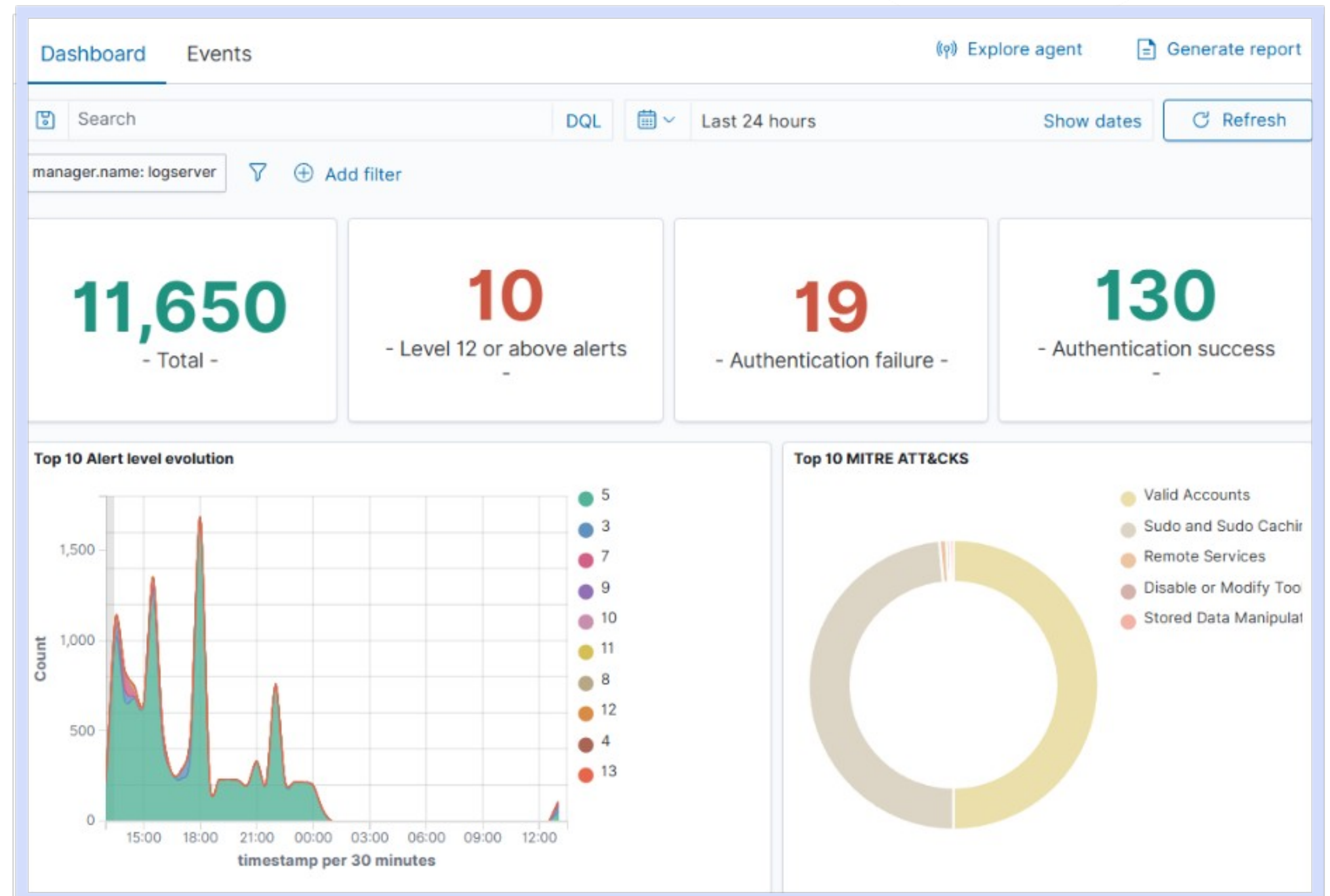
로그 서버 Agent 기반

Agents (5) [Deploy new agent](#) [Refresh](#) [Export formatted](#) [More](#) [Settings](#)

status=active [WQL](#)

☐	ID ↑	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
☐	001	ttorongi-web	100.77.91.115	default	Ubuntu 24.04.4 LTS	node01	v4.14.6	active info	eye edit delete
☐	002	ttorongi-db	100.107.17.13	default	Ubuntu 24.04.4 LTS	node01	v4.14.6	active info	eye edit delete
☐	003	ttorongi-dns	100.115.219.48	default	Ubuntu 24.04.4 LTS	node01	v4.14.6	active info	eye edit delete
☐	004	ttorongi-snort	100.109.154.86	default	Ubuntu 24.04.4 LTS	node01	v4.14.6	active info	eye edit delete
☐	005	ttorongi-waf	100.104.251.116	default	Ubuntu 24.04.4 LTS	node01	v4.14.6	active info	eye edit delete

로그 대시 보드



Syslog 기반 pfSense

Dashboards [+ Create Dashboard](#)

[Search...](#)

☐	Title	Type	Description	Last updated	Actions
☐	TTORONGI pfSense Monitoring	Dashboard	PfSense 모니터링	Jul 29, 2026 @ 16:37:18.119	edit

Rows per page: 20 [<](#) [1](#) [>](#)

06

PROJECT RESULTS
& REFLECTIONS

프로젝트 수행 결과와 프로젝트 회고

구축·진단·탐지·재검증 결과를 종합하고,
팀원별 수행 경험과 프로젝트 성과를 정리합니다.

01

수행 결과

서비스·인프라·보안 환경 구축 성과 정리

02

프로젝트 회고

팀별 수행 경험과 프로젝트 성과 종합

06. 프로젝트 수행 결과



●서비스 · 인프라 구축

- 웹 · DB · 로그 서버 구성
- 네트워크 영역 분리
- 보안솔루션 연동



●취약점 진단 및 개선

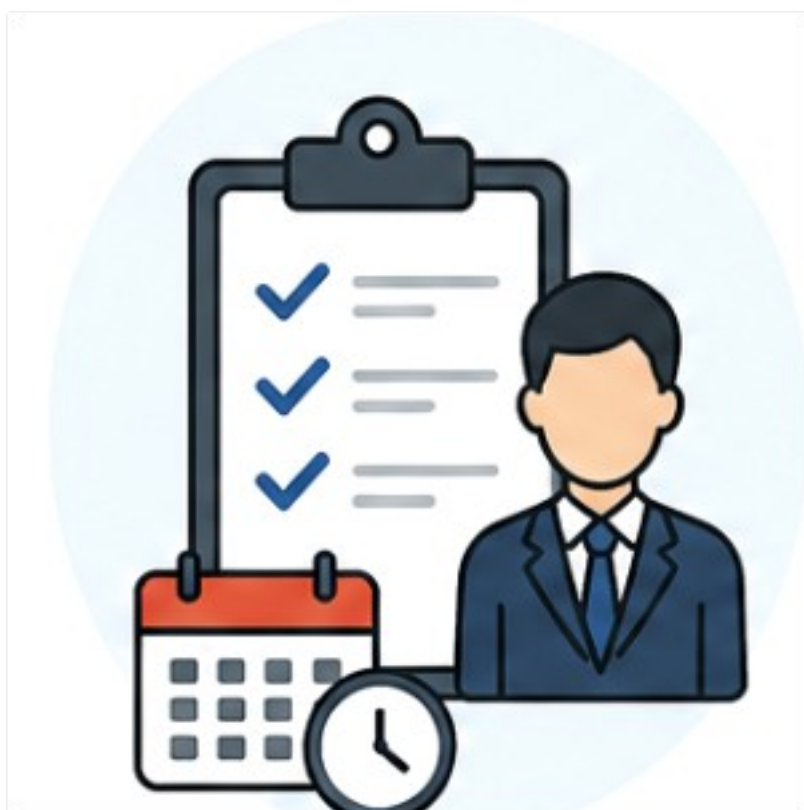
- 5 개 취약점 재현
- 구조적 원인 분석
- 보안 통제 적용 및 재검증



●악성코드 분석 및 탐지

- 정적 · 동적 특징 분석
- 실행 중 파일 변조 행위 확인
- Snort · Wazuh 기반 탐지 검증

06. 팀 소감



프로젝트 총괄 및 시스템 통합

김보미

전체 구축 방향을 기획·설계하고, 보안을 유지하며 주제에 맞는 결과물을 완성할 수 있어 힘들지만 보람 있었습니다. 끝까지 함께 최선을 다해주신 팀원분들께 감사드립니다.



보안 솔루션 구축 및 악성코드

분석 홍기수

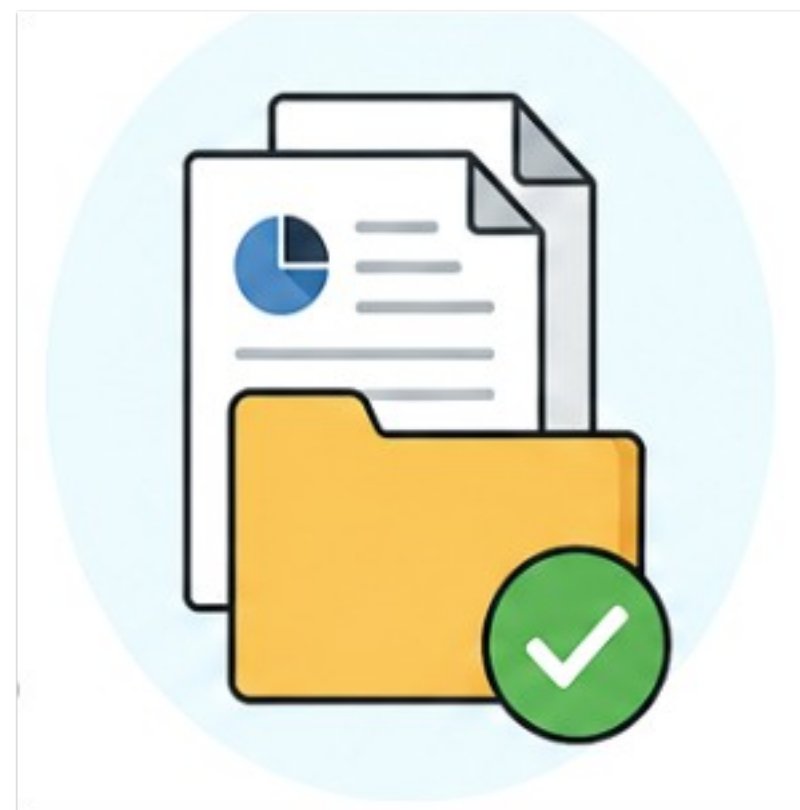
pfSense 및 악성코드 분석 실무를 주도하며 네트워크 보안 역량을 한층 높였습니다. 끝까지 든든하게 이끌어주신 보미 팀장님과 팀원들께 깊이 감사드립니다.



서비스 점검 및 공격 시나리오

수행 유성우

공격 시나리오를 직접 설계·수행하면서 취약점의 영향과 보완 과정을 경험했고, Wazuh 로그 검증과 재검증을 통해 탐지와 개선의 중요성을 배울 수 있어서 즐겁고 뜻깊은 시간이었습니다.



증적 수집 및 자료 정리

김정훈

프로젝트 진행 과정에서 발생하는 주요 분석 결과와 증적들을 꼼꼼하게 수집하고 정돈했습니다. 팀원들이 수행한 작업의 객관적 근거를 명확히 남기고 보고서의 완성도를 높이는 데 기여할 수 있어서 매우 뜻깊은 경험이었습니다.